UNIVERSIDAD MARIANO GÁLVEZ DE GUATEMALA

FACULTAD DE INGENIERÍA EN SISTEMAS DE INFORMACIÓN

MAESTRÍA EN SEGURIDAD INFORMÁTICA

PROGRAMA DE POSGRADOS

PROYECTO FINAL

GUÍA MAESTRA DEL PROYECTO FINAL

Diseño e Implementación de un Sistema de Gestión de Seguridad de la Información (SGSI)

Escenario: Universidad Mariano Sanchez (organización ficticia del sector educación)

Autor (es):

Hector Rodrigo Sánchez García, 1593-20-12173, hsanchezg2@miumg.edu.gt
Paulino Josué Arrecis Rivera, 1593-17-2874, parecisr@miumg.edu.gt
Jose Jovani Idelfonso, 1593-13-21657, jidelfonso@miumg.edu.gt
Erick Neftalí Molina Serech, 1593-11-3388
Gustavo Adolfo Delgado Quevedo, 1593-12-10445
Kevin Miguel Escot Soto, 1593-16-9744, kescots@miumg.edu.gt

Profesor

CRISTIAN WALDEMAR ROSALES MELENDEZ

Curso

(Estándares De Seguridad – 4to - 2026)

Guatemala, 2026

Tabla de contenido

1. Propósito y uso de esta guía....1
1.1 Fuentes utilizadas y jerarquía....1
1.2 Advertencia sobre la guía didáctica....2
2. Decisión de arquitectura: construcción local con WDS....2
2.1 Lo que cambió y por qué importa....2
2.2 Cómo mantener cubierto el requisito híbrido y móvil....3
3. Cronograma de 10 semanas....5
4. Aprobación del diagrama antes de construir....6
5. Fases del proyecto y contenido de los entregables....7
5.1 Fase 1. Diseño de infraestructura (E1)....7
5.2 Fase 2. Construcción del ambiente aprobado (E2): plan local con WDS en VirtualBox....9
5.3 Fase 3. Modelo de gestión de seguridad (E3)....26
5.4 Fase 4. Implementación y gestión de riesgos (E4.1 a E4.6)....29
5.5 Fase 5. Políticas, controles y buenas prácticas (E5)....35
5.6 Fase 6. Gobernanza y gestión de servicios de TI (E6)....37
5.7 Fase 7. Continuidad del negocio y Data Center (E7)....39
6. Discusión académica: las 6 preguntas obligatorias....40
7. Estructura del documento final y contenido mínimo de Resultados....41
7.1 Estructura obligatoria (sección 11 del enunciado)....41
7.2 Los 20 puntos obligatorios de Resultados (sección 12 del enunciado)….41
8. Formato obligatorio (sección 14 del enunciado)....42
9. Rúbrica de evaluación (sección 16 del enunciado)....43
10. Reglas del proyecto....45
10.1 Evidencias (sección 15 del enunciado)....45
10.2 Originalidad (sección 17 del enunciado)....45
10.3 Uso de inteligencia artificial (sección 18 del enunciado)....46
10.4 Presentación y defensa (sección 19 del enunciado)....46
11. Asignación del grupo y observaciones al borrador....47
11.1 Asignación de los entregables de la Fase 1....47
11.2 Observaciones al borrador actual (ProyectoFinal.docx)....47
12. Lista de verificación final (sección 20 del enunciado)....49
13. Preguntas abiertas y decisiones pendientes....50
Referencias....51
Anexo A. Figura 1 a página completa....54
Anexo B. Hoja de direccionamiento propuesta....55

1. Propósito y uso de esta guía

Con esta guía maestra buscamos reunir, en un solo documento, todo lo que como Grupo 3 debemos producir para el proyecto final del curso Estándares de Seguridad: el diseño e implementación de un Sistema de Gestión de Seguridad de la Información (SGSI) para la Universidad Mariano Sanchez, la universidad ficticia que acordamos como escenario. En sus páginas se encuentran el cronograma, las fases y sus entregables, el plan de construcción del ambiente, la estructura y el formato del documento final, la rúbrica, las reglas académicas y la lista de verificación.

Conviene aclarar desde el inicio que se trata de una guía y una plantilla, no del informe final. Por esa razón no contiene evidencias, capturas, mediciones ni resultados. Donde aparecen tablas, sus filas son encabezados o marcadores «[completar]» que debemos llenar con trabajo propio y verificable, y ningún valor de esta guía debe copiarse al informe como si fuera un resultado obtenido.

1.1 Fuentes utilizadas y jerarquía

Tabla 1

Fuentes de la guía y prioridad

Prioridad	Fuente	Uso en esta guía
1	Enunciado oficial: PROYECTO.FINAL.ESTANDARES.DE.SEGURIDAD.2026.docx, secciones 1 a 20 del enunciado (Universidad Mariano Gálvez de Guatemala [UMG], 2026b).	Fuente que rige: fases, entregables, cronograma, formato, rúbrica, evidencias, originalidad, IA, defensa y lista de verificación.
Modificación pendiente de confirmación escrita	Indicación verbal del docente transmitida al grupo: la nube pública no es obligatoria y la Fase 2 se construye en máquinas locales con WDS como base.	Solo modifica la Fase 2 y la arquitectura del laboratorio, y solo cuando llegue la confirmación escrita (apartado 2.1 de esta guía). Hasta entonces, el enunciado prevalece.
2	Guía didáctica 093-003, Estándares de Seguridad 2026 (UMG, 2026a).	Contexto del curso y referencias; describe otro proyecto (ver 1.2).
3	Borrador del grupo (ProyectoFinal.docx) y cronograma del grupo (Cronograma.xlsx).	Diagnóstico del avance y lista de correcciones (apartado 11 de esta guía).
4	Skill compartida sgsi-proyecto-umg y revisiones internas de esta guía.	Criterios de revisión, trazabilidad y prácticas de trabajo.

Convención de referencias. En esta guía, «sección N del enunciado» remite a las secciones numeradas del enunciado oficial (UMG, 2026b), y «punto» se usa para sus incisos (por ejemplo, el punto 4.1 de la sección 9 del enunciado). En cambio, «apartado N de esta guía» remite a los capítulos y subcapítulos de este documento. Las tablas y figuras se citan por su número (Tabla N, Figura N).

1.2 Advertencia sobre la guía didáctica

La guía didáctica 093-003 describe un proyecto final distinto: una «propuesta de adopción y armonización de estándares» para una organización guatemalteca, con Declaración de Aplicabilidad, mapeo (crosswalk) entre marcos y ruta de certificación, entregables sin calificación en las semanas 4, 7 y 8, un máximo de 40 páginas más anexos, coevaluación del 10 % y grupos de hasta 4 integrantes. El Grupo 3 tiene 6 integrantes y trabaja con el enunciado oficial del SGSI. **Manda el enunciado oficial** mientras el docente no indique lo contrario.

Aun así, consideramos útil aprovechar de la guía didáctica aquello que sí complementa el enunciado: una Declaración de Aplicabilidad (SoA) parcial sobre el Anexo A de ISO/IEC 27001:2022 (International Organization for Standardization [ISO] e International Electrotechnical Commission [IEC], 2022a), un perfil actual y objetivo de NIST CSF 2.0 (National Institute of Standards and Technology [NIST], 2024) y un mapeo breve de controles con CIS Controls v8 (Center for Internet Security [CIS], 2021). Además, es prudente preguntar al docente si el límite de 40 páginas aplica a este proyecto.

2. Decisión de arquitectura: construcción local con WDS

2.1 Lo que cambió y por qué importa

Según indicación verbal transmitida al grupo, sin confirmar por escrito, el docente señaló en clase que la nube pública (Azure) no es obligatoria y que la Fase 2 puede ser una construcción real sobre máquinas locales (máquinas virtuales), usando Windows Deployment Services (WDS) sobre Windows Server como base de despliegue. Con base en lo anterior, el grupo preparó la Fase 2 siguiendo esa indicación, con Oracle VirtualBox como hipervisor único (decisión del grupo). Sin embargo, la tratamos como una modificación pendiente de confirmación escrita.

> **Importante.** Esta decisión **se aparta del enunciado escrito**. La sección 4 del enunciado exige «nube híbrida con soporte para dispositivos móviles, tablets, computadores» que «deberá integrar infraestructura local con servicios de nube pública», y la sección 5 del enunciado exige seleccionar Microsoft Azure, AWS o GCP y usarla «para implementar o demostrar los componentes tecnológicos». La lista de verificación (sección 20 del enunciado) también pide «controles para la conectividad segura con la nube». Mientras no exista confirmación escrita, el grupo corre el riesgo de que la evaluación siga el texto del enunciado.

Por ello, recomendamos pedir al docente la confirmación por escrito (correo o comentario en Classroom) antes de iniciar la construcción y archivarla en los anexos del informe. En concreto, la consulta debe aclarar cuatro puntos:

1. Que la Fase 2 puede implementarse completamente en máquinas virtuales locales con WDS, sin nube pública.
2. Cómo se evaluará el requisito de nube híbrida de las secciones 4, 5 y 20 del enunciado: si basta con mantener la nube en el diseño (E1) marcada como «diseñada, no implementada», o si se espera un componente mínimo de nube.
3. Si el soporte de dispositivos móviles puede demostrarse con un dispositivo o emulador en laboratorio.
4. Si el límite de 40 páginas y los grupos de hasta 4 integrantes de la guía didáctica aplican a este proyecto.

Borrador de mensaje (lo envía un integrante del grupo, en nombre del grupo, por el canal oficial):

> **Mensaje sugerido.** Buen día, ingeniero Rosales. Le escribe [nombre del integrante], integrante del Grupo 3, en nombre del grupo (SGSI para la Universidad Mariano Sanchez). En clase nos indicó que la nube pública no es obligatoria y que la Fase 2 puede construirse en máquinas virtuales locales usando WDS sobre Windows Server; planeamos hacerlo en VirtualBox. Para alinear la evaluación con el enunciado (secciones 4, 5 y 20, que piden nube híbrida con Azure, AWS o GCP), ¿nos confirma por favor: (1) que la implementación local con WDS es válida para el E2; (2) si basta con mantener el componente de nube en el diseño como «diseñado, no implementado», o si espera algún componente mínimo de nube; y (3) si el soporte móvil puede demostrarse con un dispositivo o emulador en laboratorio? Adjuntaremos su respuesta como anexo del informe. Gracias. [Nombre y carné del integrante que envía]

2.2 Cómo mantener cubierto el requisito híbrido y móvil

Para que la decisión de construir en local no deje vacíos frente a la rúbrica, proponemos tres niveles de cobertura. Una vez recibida la respuesta del docente, el grupo elegirá uno y lo justificará en la Metodología.

Tabla 2

Opciones para cubrir el requisito de nube híbrida y móvil

Opción	Qué se hace	Ventajas	Riesgos o costos
A. Híbrido simulado (recomendad	Diseño (E1) híbrido completo con la nube elegida (por ejemplo Azure) marcada	Demuestra los controles de conectividad	No es nube pública; depende de la

Opción	Qué se hace	Ventajas	Riesgos o costos
a si el docente acepta sin nube)	«Diseñado, no implementado». En el laboratorio, un segundo sitio local («Sitio DR / nube privada», 10.50.0.0/16) conectado por VPN IPsec sitio a sitio entre dos firewalls, que recibe la copia externa de respaldos y aloja la recuperación.	híbrida (túnel cifrado, rutas mínimas, reglas, registro) sin costo ni cuentas de nube.	confirmación escrita del docente. No hay modelo de responsabilidad compartida: el grupo asume toda la pila (física, hipervisor, sistema operativo, red e identidad) y lo documenta en el E1.
B. Componente mínimo de nube	Opción A más un servicio de nube de costo cero o con crédito académico (por ejemplo, copia externa de respaldos o un inquilino de identidad de prueba) en la plataforma elegida.	Cumple literalmente la sección 5 del enunciado con poco esfuerzo.	Requiere cuenta y control de costos; nunca publicar credenciales; verificar las condiciones vigentes del plan gratuito o académico.
C. Solo justificación	Mantener la nube únicamente en el diseño, con una justificación técnica y de riesgo.	Menor esfuerzo.	Mayor riesgo de perder puntos en diseño (15 %) e implementación (10 %).

Por otro lado, la cobertura móvil se mantiene en cualquiera de las opciones mediante un segmento BYOD/móviles separado del de invitados, acceso remoto por VPN con MFA, inscripción de al menos un dispositivo Android (físico de laboratorio o máquina virtual o emulador) en una solución MDM, y controles DLP documentados. Si la solución MDM elegida es de nube (por ejemplo Microsoft Intune), se declara como dependencia de nube; si es local (por ejemplo una edición comunitaria autoalojada), se instala en el segmento de servidores. En cualquier caso, debemos verificar la licencia y la versión vigentes antes de elegir.

3. Cronograma de 10 semanas

A continuación se presenta el cronograma oficial (sección 13 del enunciado), expresado en semanas relativas; la semana 1 corresponde a la asignación del proyecto. En la columna «Trabajo del Grupo 3» adaptamos cada semana a la construcción local con WDS y al reparto de tareas.

Tabla 3

Cronograma oficial del enunciado (sección 13) y su adaptación al Grupo 3

Semana	Actividad (sección 13 del enunciado)	Entregable	Trabajo del Grupo 3 (adaptación)
1	Asignación del proyecto	Enunciado y selección del escenario	Confirmar escenario (Universidad Mariano Sanchez); enviar consulta escrita al docente; repartir la Fase 1; confirmar VirtualBox como hipervisor y elegir la herramienta de diagramas.
2	Diseño conceptual	E1. Arquitectura y diagrama	Completar el E1; presentar el diagrama para aprobación (apartado 4 de esta guía); instalar VirtualBox y preparar las ISO y el anfitrión del laboratorio.
3	Aprobación y construcción	E2. Ambiente tecnológico	Con el diagrama aprobado (y la confirmación escrita): construir el laboratorio en VirtualBox (firewall, AD DS, DNS, DHCP, WDS, clientes, SIEM, respaldo); registrar evidencias por paso.
4	SGSI y activos	E3 + E4.1	Modelo del SGSI (alcance, contexto, roles, política); inventario de activos alineado con el laboratorio y el diseño.
5	BIA	E4.2	Procesos críticos, impactos, MTPD, RTO y RPO; contrastar con la prueba de restauración del E2.
6	Análisis de riesgos	E4.3 + E4.4	Matriz NIST SP 800-30 (Joint Task Force Transformation Initiative, 2012) y evaluación OCTAVE Allegro (Caralli et al., 2007).
7	Matriz y tratamiento	E4.5 + E4.6	Matriz de calor 5×5 con criterios; plan de tratamiento y riesgo residual esperado.
8	Controles y políticas	E5 (E5.1, E5.2, E5.3)	Políticas por bloque, matriz de controles ligada a riesgos (Anexo A), buenas prácticas; GPO del laboratorio como evidencia.

Semana	Actividad (sección 13 del enunciado)	Entregable	Trabajo del Grupo 3 (adaptación)
9	Gobierno, continuidad y Data Center	E6 + E7	COBIT 2019 (ISACA, 2018) e ITIL 4 (AXELOS, 2019); BCP, DRP y prueba de recuperación; buenas prácticas TIA-942 (Telecommunications Industry Association [TIA], 2024).
10	Entrega final y defensa	Documento final + presentación	Integración, formato (sección 14 del enunciado), APA 7, lista de verificación (sección 20 del enunciado); ensayo de la defensa (15 a 25 min) con todos los integrantes.

Observación. El archivo Cronograma.xlsx del grupo contiene un plan de **7 semanas** y declara «diseño teórico aplicado; sin implementación tecnológica». Ambas cosas contradicen el enunciado (10 semanas, sección 13) y la decisión de construir en local (Fase 2). Debe actualizarlo quien lo administra; esta guía no modifica archivos compartidos.

Cabe señalar que las semanas 3 y 4 son las de mayor carga, porque concentran la construcción del ambiente y tres entregables (E2, E3 y E4.1). De esta forma, conviene adelantar en la semana 2 las imágenes ISO, el anfitrión del laboratorio, el plan de direccionamiento y un inventario preliminar de activos.

4. Aprobación del diagrama antes de construir

El enunciado (sección 9, Fase 1) establece que el diagrama debe presentarse al docente para aprobación una semana después de la asignación del proyecto, y que la aprobación del diseño es requisito para continuar con la construcción del ambiente. En ese sentido, **no construiremos nada de la Fase 2 sin la aprobación del diagrama**.

- Presentar un único diagrama oficial (una sola herramienta, por ejemplo draw.io), con los mismos identificadores de VLAN, subredes y nombres de equipos que aparecen en las tablas del E1 y en el plan del laboratorio. Para la vista del laboratorio puede partirse de la Figura 1 (apartado 5.2.3 de esta guía), que debe redibujarse en la herramienta oficial y validarse con las tablas.
- Incluir en el diagrama: zonas de seguridad (Internet, DMZ, usuarios, BYOD/móviles, invitados, servidores, datos, SOC, respaldo, gestión), el NGFW como punto de paso del tráfico entre VLAN, el IDS/IPS, el SIEM, los flujos principales y el sitio de recuperación o la nube.
- Distinguir con leyenda lo que se implementará en el laboratorio y lo que queda solo diseñado. En la vista del laboratorio, rotular cada VLAN con su red interna

de VirtualBox (por ejemplo VLAN 30 = ums-v30) y mostrar FW01 como único punto de paso entre segmentos.

- Registrar la aprobación (fecha relativa, medio, comentarios del docente y cambios solicitados) y adjuntarla como anexo. Si el docente pide cambios, actualizar diagrama y tablas antes de construir.
- Cualquier cambio posterior al diagrama aprobado se registra como cambio controlado (ITIL 4, habilitación de cambios) con su justificación.

5. Fases del proyecto y contenido de los entregables

Con el cronograma y la condición de aprobación definidos, a continuación se describe, fase por fase, lo que exige la sección 9 del enunciado y lo que debe contener cada entregable. La trazabilidad que pide la rúbrica para el nivel Excelente atraviesa todas las fases: proceso → activo → impacto → riesgo → control → responsable → evidencia o método de verificación. Para sostenerla, usaremos identificadores únicos (ACT-xx, PRC-xx, R-xx, CTL-xx, EV-xx) y los repetiremos en todas las tablas.

5.1 Fase 1. Diseño de infraestructura (E1)

El objetivo de esta fase es diseñar la arquitectura tecnológica y de seguridad que soportará el SGSI. El diseño debe incluir los 19 elementos de la sección 9 del enunciado; en la columna derecha de la tabla indicamos cómo concretarlos de forma coherente con la construcción local.

Tabla 4

Elementos obligatorios del diseño en la Fase 1 (sección 9 del enunciado)

Elemento	Concreción sugerida para la Universidad Mariano Sanchez
Servidores	Controladores de dominio, servidor WDS, aplicaciones (portal y LMS), bases de datos, SIEM, respaldo; anfitriones de virtualización.
Bases de datos	Un único motor (por ejemplo PostgreSQL) en segmento de datos, sin exposición a Internet ni a usuarios.
Sistemas de almacenamiento	Elegir uno (NAS o SAN) y justificarlo; volumen separado para RemoteInstall de WDS y para respaldos.
Switches y routers	Núcleo redundante y acceso por edificio; routers de borde con doble ISP (diseño); en laboratorio, una red interna de VirtualBox por segmento.
Firewalls NGFW	Par en alta disponibilidad (diseño); pfSense CE en laboratorio como NGFW y enrutador entre segmentos (OPNsense como alternativa equivalente).
IDS/IPS	Suricata en el NGFW (interfaces WAN y DMZ) con alertas enviadas al SIEM.
DMZ	Proxy inverso y WAF para el portal; solo TCP 443 desde Internet.

Elemento	Concreción sugerida para la Universidad Mariano Sanchez
Segmentación de red	VLAN por perfil (estudiantes, docentes, administración, laboratorios, BYOD/móviles, invitados, servidores, datos, SOC, respaldo, gestión); denegar por defecto.
Virtualización y contenedores	Laboratorio: Oracle VirtualBox como hipervisor único del grupo. Producción (diseño): plataforma de virtualización a definir y justificar; si difiere de VirtualBox, explicarlo en la tabla de diseñado frente a implementado. Contenedores solo si una aplicación lo justifica.
IAM y MFA	AD DS como identidad central; RBAC por grupos; MFA para administración, acceso remoto y aplicaciones web.
Zero Trust	Sin confianza implícita por estar en la LAN o la VPN: identidad, dispositivo y contexto por solicitud; bastión para gestión (NIST SP 800-207; Rose et al., 2020).
SIEM	Wazuh: recolección de eventos de Windows, Linux, firewall y Suricata; reglas y tableros.
Respaldo, redundancia y alta disponibilidad	Regla 3-2-1-1-0 (copia externa en el sitio DR o en un disco desconectado); DC redundante; conmutación de DHCP; HA del firewall en diseño.
Continuidad y recuperación	Sitio de recuperación (nube o sitio DR simulado); RTO y RPO derivados del BIA.

Contenido mínimo del E1 (Documento de diseño de infraestructura):

- Descripción del escenario (organización, tamaño, estructura, procesos, usuarios, servicios y necesidades de seguridad, sección 3 del enunciado).
- Diagrama de arquitectura.
- Descripción de componentes.
- Flujos de comunicación.
- Segmentación de red.
- Controles de seguridad.
- Mecanismos de redundancia.
- Estrategia inicial de continuidad y recuperación.
- Justificación técnica de la solución.

Si la Fase 2 se construye en local, el E1 debe explicar la relación entre el diseño institucional (a escala real) y el laboratorio (a escala reducida), es decir, qué componentes del diseño representa cada máquina virtual y qué queda fuera. Además, en una construcción local el grupo asume toda la pila (instalación física, hipervisor, sistema operativo, red e identidad), a diferencia del modelo de responsabilidad compartida de una nube pública. Esto también se declara en el E1.

5.2 Fase 2. Construcción del ambiente aprobado (E2): plan local con WDS en VirtualBox

Como se mencionó en la fase anterior, la construcción solo inicia cuando el diseño está aprobado. A partir de ese momento, el grupo debe construir una implementación funcional o demostrable. La sección 9 del enunciado pide demostrar, según corresponda: redes, subredes, segmentación, servicios cloud, servidores, aplicaciones, bases de datos, IAM, MFA, controles de acceso, seguridad perimetral, monitoreo, registro de eventos, backup y recuperación. El E2 debe incluir: descripción de la implementación, evidencias técnicas, capturas de configuración, direccionamiento y segmentación, servicios implementados, controles configurados, pruebas realizadas y resultados obtenidos, **diferenciando claramente lo diseñado de lo efectivamente implementado**.

> **Condición.** Este plan aplica la modificación verbal sobre la Fase 2 (construcción local con WDS). Mientras no exista la confirmación escrita del docente (apartado 2.1 de esta guía), el grupo debe tratarlo como propuesta y conservar en el E1 el diseño híbrido que exige el enunciado.

5.2.1 Principios del laboratorio

- **Hipervisor único: Oracle VirtualBox 7.2.x** (serie vigente en la página oficial de descargas; verificar la build exacta), con **la misma build en todos los anfitriones** (uno o dos equipos de los integrantes). La build se declara en el E1 y el E2 y se cita el manual de esa versión.
- Todo el software se obtiene de fuentes oficiales (versiones de evaluación o gratuitas) y se verifica su hash. No se usan licencias ni imágenes de origen dudoso.
- Se reutilizan los identificadores del diseño (VLAN y subredes 10.20.x.0/24) para que el laboratorio sea una muestra fiel del diseño, aunque en VirtualBox cada «VLAN» sea una red interna (ver 5.2.3).
- Cada paso genera evidencia identificada (EV-E2-Pxx-nn) antes de pasar al siguiente. Lo que no se pudo implementar se declara «Diseñado, no implementado», sin capturas sustitutas.
- Antes de cada paso riesgoso se toma una instantánea (snapshot) de las máquinas afectadas, con nombre y fecha relativa, para poder volver atrás. Una instantánea **no es un respaldo** (vive en el mismo disco y en el mismo anfitrión).
- No se publican contraseñas, claves de recuperación de BitLocker, tokens, semillas de OTP ni datos personales reales en ninguna captura (sección 15 del enunciado).

5.2.2 Limitaciones de VirtualBox que deben declararse

- **Sin troncales 802.1Q nativas.** En VirtualBox, cada segmento se implementa como una red interna independiente y FW01 (pfSense) tiene un adaptador por

segmento y enruta y filtra entre ellos (Oracle, s. f.). Equivale funcionalmente a la segmentación por VLAN del diseño, y así se explica en el E2.

- **Número de adaptadores.** Con el chipset PIIX3 una máquina admite 8 adaptadores; con el chipset ICH9, hasta 36, pero el manual de VirtualBox lo califica de experimental. La interfaz gráfica solo muestra 4 adaptadores; los demás se configuran con VBoxManage modifyvm. Si ICH9 falla, se aplica el plan alterno de 5.2.3.
- **Arranque PXE: adaptador y tipo de red.** La máquina cliente usa el adaptador Intel PRO/1000 MT Desktop (82540EM), recomendado, o virtio-net (por verificar: hay reportes de la comunidad de fallos de PXE con EFI), conectado a una Red interna (o a una Red NAT). No se usa el modo NAT simple: aunque admite PXE con su propio DHCP y TFTP, aísla cada máquina y no deja llegar a WDS01. «Red» va primero en el orden de arranque. El ROM PXE de Intel lo aporta el Extension Pack de VirtualBox, que tiene licencia propia (PUEL; verificar condiciones de uso); sin él se usa el ROM PXE genérico.
- **DHCP del laboratorio:** lo entrega Windows Server (DC01), no VirtualBox. Las redes internas no tienen DHCP propio salvo que se cree uno; si se usa una Red NAT para un segmento de clientes, se desactiva su DHCP. Así el PXE recibe las respuestas de DC01 y WDS01 a través del relay de FW01.
- **BIOS o EFI (decisión documentada).** Windows 11 exige UEFI, arranque seguro y TPM 2.0, que VirtualBox 7 ofrece. Pero el PXE con EFI en VirtualBox puede ser poco fiable: según reportes de la comunidad (por verificar; el manual oficial no lo documenta), puede requerir entrar al gestor de arranque UEFI (tecla Esc al encender) y algunas versiones 7.1 tuvieron fallos. Propuesta: (1) intentar PXE con EFI en las máquinas Windows 11; (2) si falla, demostrar el PXE con una máquina en BIOS que carga la imagen WinPE personalizada; y (3) instalar Windows 11 en EFI desde la ISO. La elección y el resultado se registran en el E2; si se llega al paso (3), la prueba PR-03 se reporta como cumplimiento parcial.
- **Evidencia de la plataforma:** registrar la versión exacta de VirtualBox (Ayuda > Acerca de, o VBoxManage --version) y del Extension Pack si se usa. Adjuntar capturas reales de la configuración de red de cada máquina (pestaña Red, tipo de adaptador, red interna) y de VBoxManage showvminfo con los adaptadores de FW01. No se aceptan capturas recreadas ni simuladas.
- **Soporte.** Microsoft no documenta VirtualBox como plataforma probada para clientes o servidores WDS, y las herramientas de Microsoft no se integran con VirtualBox (a diferencia de su propio hipervisor). El soporte de los sistemas invitados Windows en VirtualBox corresponde a Oracle (verificar). Es aceptable para un laboratorio académico, pero se declara como limitación y riesgo (E4.3).
- **Plan alterno.** Si el arranque PXE no funciona en una máquina, se instala desde la ISO montada y se deja constancia del fallo y de su causa. El arranque PXE se demuestra al menos una vez (por ejemplo, con firmware BIOS cargando la imagen WinPE personalizada).

5.2.3 Topología del laboratorio

La topología del laboratorio es una versión reducida del diseño. Cada segmento es una red interna de VirtualBox con nombre propio (por ejemplo ums-v30), y FW01 tiene un adaptador en cada una de ellas, de modo que es el único punto de paso entre segmentos. La salida a Internet usa una Red NAT de VirtualBox. Durante la instalación puede usarse temporalmente un adaptador solo-anfitrión (host-only) para administrar FW01; después se desactiva. Por supuesto, todo esto debe validarse contra el diagrama aprobado. La Figura 1, al final de este apartado, resume nuestra propuesta a partir de la Tabla 5.

Tabla 5

Segmentos del laboratorio (propuesta; validar con el diagrama aprobado)

VLAN	Subred	Zona	Red de VirtualBox	Máquinas	Regla principal	Estado
WAN	Red NAT	Internet	natnet-wan	FW01 (adaptador 1)	Solo salida controlada; entrada únicamente TCP 443 hacia la DMZ.	Implementar
10	10.20.10.0/24	DMZ	ums-v10	PRX01	Desde Internet solo 443; hacia APP01 solo el puerto de la aplicación.	Implementar
20	10.20.20.0/24	Estudiantes	ums-v20	CLI-EST01	Portal, LMS y DNS; sin acceso a datos ni gestión.	Implementar
21	10.20.21.0/24	Docentes	ums-v21	Ninguna	LMS y calificaciones por aplicación.	Diseñado; opcional (mismo patrón que la 20)
22	10.20.22.0/24	Administración	ums-v22	CLI-ADM01	Aplicaciones administrativas autorizadas.	Implementar
23	10.20.23.0/24	Laboratorios	ums-v23	Ninguna	Aislamiento por aula.	Diseñado; opcional
24	10.20.24.0/24	Invitados	ums-v24	CLI-INV01 (cliente de prueba)	Solo Internet; bloquear redes internas y resolución DNS interna.	Implementar

VLAN	Subred	Zona	Red de VirtualBox	Máquinas	Regla principal	Estado
25	10.20.25.0/24	BYOD / móviles	ums-v25	MOB01	Solo Internet y VPN con MFA; servicios según cumplimiento MDM.	Implementar
30	10.20.30.0/24	Servidores e identidad	ums-v30	DC01, DC02, WDS01, APP01	Servicios de dominio solo desde clientes del dominio.	Implementar
31	10.20.31.0/24	Datos	ums-v31	DB01	Solo desde APP01 al puerto de la base de datos.	Implementar
40	10.20.40.0/24	SOC	ums-v40	SIEM01	Ingesta de agentes y syslog; consola solo desde gestión.	Implementar
80	10.20.80.0/24	Respaldo	ums-v80	BKP01	Credenciales independientes del dominio; sin acceso de usuarios.	Implementar
99	10.20.99.0/24	Gestión	ums-v99	MGMT01	Administración solo desde el bastión con MFA.	Implementar
DR	10.50.0.0/16	Sitio DR (opción A)	Segundo anfitrión	FW02, DR01	Túnel IPsec sitio a sitio; rutas mínimas.	Opcional

Con los 11 segmentos a implementar (13 si se agregan las opcionales 21 y 23), FW01 necesita de 11 a 13 adaptadores, más el adaptador solo-anfitrión temporal: requiere el chipset ICH9, porque PIIX3 admite solo 8. La VLAN 25 BYOD/móviles no existe en el borrador actual: se propone para cubrir el soporte móvil de la sección 4 del enunciado y debe agregarse al diagrama y a la tabla de segmentación del E1.

Plan alterno si ICH9 falla. Hay dos opciones; en ambas se conservan Respaldo (ums-v80), Gestión y bastión (ums-v99) e Invitados (ums-v24), para que P10, P12, P13, PR-05, PR-09 y PR-12 sigan siendo posibles:

Tabla 6

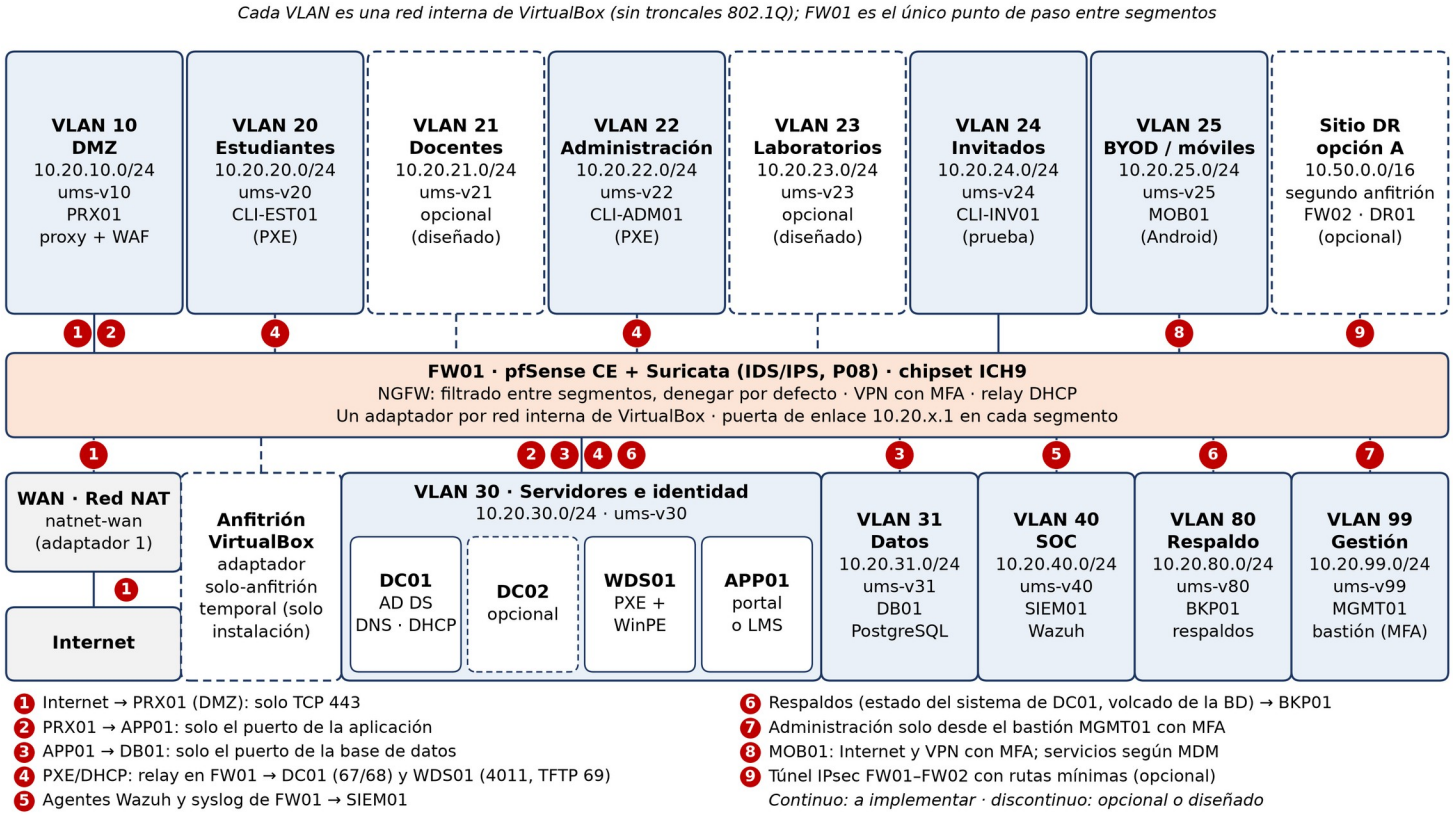
Plan alterno de segmentos si el chipset ICH9 no funciona

Opción	Segmentos	Pruebas afectadas
1. FW01 con PIIX3 y 8	WAN; 10 DMZ; 20 Estudiantes; 22 Administración; 24	PR-01 y la separación

Opción	Segmentos	Pruebas afectadas
adaptadores (segmentos fusionados)	Invitados + 25 BYOD (un solo segmento, con acceso a servicios solo por VPN con MFA); 30 Servidores + 31 Datos (DB01 limitado por su propio firewall a APP01); 80 Respaldo; 99 Gestión + 40 SOC (consola e ingesta del SIEM en el segmento de gestión).	servidores-datos se demuestran con el firewall de DB01, no con FW01; el aislamiento entre Invitados y BYOD queda «Diseñado».
2. Segundo firewall virtual FW01b con PIIX3	FW01: WAN, 10, 20, 22, 24, 25 y un enlace de tránsito. FW01b: tránsito, 30, 31, 40, 80 y 99. Ambos con reglas de denegación por defecto. Suricata (P08) se ejecuta en FW01, que conserva la WAN y la DMZ. El relay DHCP de FW01 llega a DC01 y WDS01 (en ums-v30, detrás de FW01b) a través del enlace de tránsito, por lo que FW01b debe permitir DHCP y PXE desde FW01 y tener las rutas de retorno.	Ninguna, pero aumenta la complejidad de rutas y reglas, que deben documentarse en la matriz de flujos.

Figura 1

Topología propuesta del laboratorio en VirtualBox: segmentos, máquinas virtuales y flujos principales



Nota. Diseño propuesto por el grupo a partir de las tablas 5, 7 y B1 y del apartado 5.2.5 de esta guía; elaboración propia. Muestra el plan principal (FW01 con chipset ICH9); las variantes de la Tabla 6, incluido FW01b (opción 2), no se dibujan. Es una propuesta pendiente de aprobación del docente, no una evidencia de implementación. Lo discontinuo es opcional o solo diseñado; los números remiten a la leyenda. Copia a página completa en el Anexo A.

5.2.4 Máquinas virtuales

Tabla 7

Máquinas virtuales propuestas en VirtualBox: 13 en el anfitrión principal, MOB01 y 2 opcionales en el sitio DR (dimensionamiento orientativo; verificar requisitos oficiales)

ID	Rol	Sistema y software	Configuración en VirtualBox	vCPU / RAM / disco	Red
FW01	NGFW, enrutamiento entre segmentos, VPN, IDS/IPS	pfSense CE + Suricata	Chipset ICH9; un adaptador por segmento (VBoxManage)	2 / 4 GB / 20 GB	WAN + todas
DC01	AD DS, DNS, DHCP	Windows Server 2022 o 2025 (evaluación)	EFI; adaptador Intel PRO/1000	2 / 4 GB / 60 GB	ums-v30
DC02	Redundancia de AD DS, DNS y DHCP	Windows Server (evaluación)	Igual que DC01	2 / 4 GB / 60 GB	ums-v30 (opcional)
WDS01	WDS solo como servidor PXE	Windows Server + Windows ADK y complemento WinPE	Segundo disco para RemoteInstall	2 / 4 GB / 60 + 80 GB	ums-v30
APP01	Portal o LMS de prueba	Linux con servidor web y aplicación de prueba	Adaptador Intel PRO/1000	2 / 4 GB / 40 GB	ums-v30
PRX01	Proxy inverso y WAF	Linux con proxy inverso	Adaptador Intel PRO/1000	1 / 2 GB / 20 GB	ums-v10
DB01	Base de datos	Linux con PostgreSQL	Adaptador Intel PRO/1000	2 / 4 GB / 40 GB	ums-v31
SIEM01	SIEM y EDR/XDR	Wazuh (todo en uno)	Adaptador Intel PRO/1000	4 / 8 GB / 80 GB	ums-v40
BKP01	Repositorio de respaldo	Linux con recurso compartido dedicado (cuenta fuera del dominio)	Disco de datos separado	2 / 4 GB / 200 GB	ums-v80

ID	Rol	Sistema y software	Configuración en VirtualBox	vCPU / RAM / disco	Red
MGMT01	Bastión de administración	Windows con RSAT	Adaptador Intel PRO/1000	2 / 4 GB / 40 GB	ums-v99
CLI-EST01, CLI-ADM01	Clientes desplegados por PXE	Windows 11 Enterprise (evaluación) con WinPE personalizado (ver 5.2.5)	EFI, arranque seguro, TPM 2.0 virtual; Intel PRO/1000; red primero en el orden de arranque	2 / 4 GB / 64 GB	ums-v20 y ums-v22
CLI-INV01	Cliente de prueba de la red de invitados (verifica el aislamiento)	Sistema de prueba sin unir al dominio	Adaptador Intel PRO/1000; temporal, se puede eliminar después de las pruebas	Mínimo del sistema elegido	ums-v24
MOB01	Dispositivo móvil	Android físico de laboratorio o Android en VirtualBox o emulador	Según el caso	Según el caso	ums-v25
FW02	Firewall del sitio DR; extremo del túnel IPsec sitio a sitio (opcional, diseñado)	pfSense CE, como FW01 (propuesta)	En el segundo anfitrión	Según el caso	Sitio DR 10.50.0.0/16 (opcional)
DR01	Recuperación en el sitio DR: recibe la copia externa de respaldos y aloja la restauración remota (opcional, diseñado)	Según el servicio que se restaure	En el segundo anfitrión	Según el caso	Sitio DR 10.50.0.0/16 (opcional)

Si todas las máquinas se encienden a la vez se necesitan más de 40 GB de RAM. Para resolverlo tenemos tres caminos: repartirlas entre dos anfitriones (lo que, de paso, permite simular el sitio DR), encenderlas por bloques en cada prueba o combinar roles (por ejemplo PRX01 y APP01). Cualquiera que sea la opción, la decisión quedará documentada.

Las IP fijas propuestas para los servidores y las interfaces de FW01 (puerta de enlace .1 de cada segmento) están en la hoja de direccionamiento del Anexo B (Tabla B1), coherente con la Tabla 5; el grupo debe confirmarlas o ajustarlas en P00.

5.2.5 Ruta de despliegue con WDS (decisión fijada)

Decisión: WDS se usa **solo como servidor PXE** que entrega una imagen de arranque **WinPE personalizada**, creada con Windows ADK y su complemento WinPE. Esa imagen aplica el install.wim de Windows 11 (por ejemplo con DISM desde un recurso compartido de WDS01). Alternativa válida: Configuration Manager (OSD) para la secuencia de instalación. **MDT no se propone:** Microsoft anunció su retiro inmediato; ya no recibe actualizaciones, correcciones ni soporte (Microsoft, s. f.-a).

- **Por qué:** Microsoft indica que no se puede hacer un despliegue completo de Windows 11 usando solo WDS con el boot.wim del medio de instalación (está bloqueado). Con Windows Server 2025 tampoco está admitido, y con Windows Server 2022 aparece un aviso de obsolescencia que no bloquea. WDS sí sigue arrancando por PXE con imágenes personalizadas (Microsoft, s. f.-b).
- **No usar Windows 10 para esquivar la limitación:** Windows 10 dejó de tener soporte el 14 de octubre de 2025 (verificar opciones de ESU). Si el grupo lo usa, debe registrarlo como riesgo en el E4.3.
- **Despliegue desatendido:** desde las actualizaciones del 14 de abril de 2026, el despliegue desatendido (hands-free) de WDS, ligado a la vulnerabilidad CVE-2026-0386 (acceso no autenticado a unattend.xml), está deshabilitado por defecto. **No se habilita la clave AllowHandsFreeFunctionality**; la automatización se hace dentro de la imagen WinPE o con la herramienta de secuencia elegida (Microsoft, 2026).
- **Obsolescencia del rol:** Microsoft anunció que el rol WDS y su PXE quedarán obsoletos en la siguiente versión de Windows Server (Microsoft, 2026). Se registra como riesgo de obsolescencia tecnológica, con un plan de migración como tratamiento.
- WDS requiere un volumen NTFS distinto del de sistema para RemoteInstall, un DNS operativo y DHCP activo. En modo integrado con AD DS, el servidor debe ser miembro del dominio.
- DHCP (DC01) y WDS (WDS01) están en servidores distintos. El PXE entre segmentos se resuelve con retransmisión DHCP (relay) en FW01 hacia ambos servidores, sin opciones DHCP 66 y 67 para clientes UEFI.

Solo se abren los puertos necesarios (DHCP 67/68, PXE 4011, TFTP 69 y el rango dinámico de transferencia del servidor), y se documentan en la matriz de flujos.

- La respuesta PXE se configura para equipos conocidos o con aprobación del administrador, para que un equipo desconocido no pueda instalarse una imagen corporativa.
- Riesgos a registrar en el E4.3: obsolescencia de WDS; desactivación del despliegue desatendido (CVE-2026-0386); uso de Windows 10 sin soporte (si se elige); plataforma de laboratorio sin soporte oficial de Microsoft y chipset ICH9 experimental.

5.2.6 Plan paso a paso y evidencia por paso

Tabla 8

Pasos de construcción P00 a P16, evidencia a capturar y controles del Anexo A de ISO/IEC 27001:2022

Paso	Actividad	Evidencia a capturar (sin secretos)	Controles
P00	Preparación: aprobación del diagrama; instalación de VirtualBox (misma versión para todos); creación de la Red NAT y de las redes internas ums-vXX; descarga de ISO oficiales con verificación de hash; hoja de direccionamiento y nombres.	Registro de aprobación; versión de VirtualBox; lista de redes (VBoxManage list natnetworks / intnets); tabla de hashes.	A.5.9, A.8.9
P01	FW01 (pfSense) con chipset ICH9 y un adaptador por red interna: interfaces, direccionamiento, NTP, regla por defecto «denegar», reglas según la matriz de flujos, envío de registros al SIEM.	Configuración de adaptadores de la VM; interfaces y reglas en pfSense; estado de NTP; exportación de configuración sin claves.	A.8.20, A.8.22, A.8.15, A.8.17
P02	DC01: IP fija, nombre, AD DS (bosque nuevo con dominio de laboratorio), DNS integrado en AD solo con actualizaciones dinámicas seguras, transferencias de zona restringidas y registro de consultas DNS.	Roles instalados; propiedades de la zona DNS; resultado resumido de dcdiag.	A.5.16, A.8.9, A.8.21
P03	Modelo por niveles: Nivel 0 = DC01, DC02, WDS01 y MGMT01; Nivel 1 = servidores;	Árbol de UO, grupos y niveles; lista de GPO; gpresult /r en un	A.5.15, A.5.17, A.5.18, A.8.2, A.8.5, A.8.15, A.8.7,

Paso	Actividad	Evidencia a capturar (sin secretos)	Controles
	Nivel 2 = estaciones. GPO «Denegar inicio de sesión» entre niveles; Windows LAPS; grupo Protected Users para administradores. UO y grupos (Administradores, Docentes, Administrativos, Estudiantes, Terceros). GPO de contraseñas, bloqueo, auditoría, firewall de Windows, Defender, BitLocker y control de USB; línea base de seguridad.	cliente; LAPS activo (sin mostrar la contraseña).	A.8.24, A.7.10, A.8.12, A.8.20, A.8.9
P04	DHCP: ámbitos por segmento, autorización en AD, retransmisión DHCP en FW01, registros de auditoría DHCP; protección contra DHCP no autorizado (en VirtualBox no hay DHCP snooping: se compensa con reglas en FW01 y la autorización en AD, y se justifica); opcional, conmutación DHCP con DC02.	Ámbitos y concesiones; configuración del relay; registro de auditoría DHCP.	A.8.20, A.8.21, A.8.14
P05	WDS01: unión al dominio; rol WDS solo como PXE; RemoteInstall en el segundo disco; respuesta PXE con aprobación del administrador; imagen de arranque WinPE personalizada (ADK) e imagen de instalación. No se habilita AllowHandsFreeFunctionality.	Consola WDS con imágenes; política PXE; solicitud pendiente aprobada; captura del registro sin la clave hands-free.	A.8.9, A.8.19, A.5.15, A.5.17
P06	CLI-EST01 y CLI-ADM01: Intel PRO/1000, red primera en el orden de arranque, EFI, arranque seguro y TPM 2.0 virtual; arranque PXE, instalación de Windows 11 con WinPE, unión al dominio, GPO, agente	Pantalla de arranque PXE; equipo en la UO correcta; gpresult; estado de BitLocker sin clave de recuperación.	A.8.1, A.8.7, A.8.24, A.8.9

Paso	Actividad	Evidencia a capturar (sin secretos)	Controles
	Wazuh. Si el PXE con EFI falla: instalación desde ISO y registro del fallo.		
P07	DMZ y aplicación: PRX01 con TLS, APP01 y DB01; la base solo acepta conexiones de APP01.	Reglas; escaneo desde la Red NAT que muestre solo 443; intento fallido de conexión a DB01 desde un cliente.	A.8.20, A.8.22, A.8.24, A.8.26
P08	Suricata en FW01 con reglas abiertas (por ejemplo ET Open); prueba controlada que genere una alerta benigna.	Alerta en Suricata y la misma alerta en Wazuh.	A.8.16
P09	SIEM01: Wazuh todo en uno; agentes en servidores y clientes; syslog de FW01; módulos de integridad de archivos y vulnerabilidades.	Agentes activos; inicios de sesión fallidos correlacionados; alerta de integridad.	A.8.15, A.8.16, A.8.8
P10	MFA: opción local elegida (5.2.7) para VPN, bastión y aplicación web.	Solicitud del segundo factor; intento sin segundo factor rechazado.	A.8.5, A.5.17
P11	Acceso remoto y móviles: VPN en FW01 con MFA; MOB01 en ums-v25; inscripción MDM; bloqueo, cifrado y borrado remoto; controles DLP.	Dispositivo inscrito y en cumplimiento; política aplicada; bloqueo de copia a USB en un cliente.	A.6.7, A.8.1, A.8.12, A.7.10
P12	Respaldo: estado del sistema de DC01 con Windows Server Backup hacia BKP01; volcado de la base de datos; exportación de máquinas virtuales (VBoxManage export) fuera de línea; copia externa en el sitio DR o en un disco desconectado.	Trabajos de respaldo exitosos; política de retención; lista de copias externas.	A.8.13
P13	Prueba de restauración: instantánea previa; borrar un objeto de AD y recuperarlo; restaurar la base de datos en una instancia	Tiempos medidos; verificación de integridad (hash o conteo de registros); nombres de	A.8.13, A.5.30

Paso	Actividad	Evidencia a capturar (sin secretos)	Controles
	de prueba; medir tiempos frente al RTO y RPO del BIA; volver a la instantánea al terminar.	instantáneas usadas.	
P14	Redundancia (opcional): DC02 con replicación; conmutación DHCP; prueba apagando DC01.	Resumen de replicación; cliente que sigue autenticando con DC01 apagado.	A.8.14
P15	Sitio DR o nube (opción A o B): FW02 en un segundo anfitrión, túnel IPsec, copia externa y restauración remota.	Estado del túnel; reglas mínimas; restauración en el sitio DR.	A.5.23 (si hay nube), A.8.20, A.8.14, A.8.24, A.5.14
P16	Cierre: tabla de diseñado frente a implementado, inventario final de máquinas, exportación de configuraciones y registro de evidencias.	Tabla 11 (apartado 5.2.9 de esta guía) completa; registro de evidencias; configuraciones exportadas sin secretos.	A.5.9, A.5.37, A.8.9

Nota. Mapeo revisado contra la numeración de ISO/IEC 27001:2022 Anexo A. Confirmar con la norma adquirida antes de la entrega.

5.2.7 Opciones de MFA, MDM y DLP compatibles con un laboratorio local

Tabla 9

Alternativas (elegir una por necesidad y justificarla; verificar versión y licencia vigentes)

Necesidad	Opción local	Opción con dependencia de nube	Comentario
MFA para VPN y administración	Servidor RADIUS con OTP (por ejemplo privacyIDEA con FreeRADIUS, o el paquete RADIUS del firewall).	Proveedor MFA en la nube (por ejemplo Entra ID o Duo).	La opción local evita depender de Internet.
MFA para aplicaciones web	Proveedor de identidad autoalojado con TOTP o WebAuthn (por ejemplo Keycloak) federado con AD por LDAPS.	Entra ID con acceso condicional.	Preferir factores resistentes al phishing (FIDO2/WebAuthn) para administradores.

Necesidad	Opción local	Opción con dependencia de nube	Comentario
MFA en inicio de sesión de Windows	Proveedor de credenciales de terceros con OTP (verificar compatibilidad).	Windows Hello for Business con Entra ID.	Opcional; mínimo: MFA en accesos privilegiados y remotos.
MDM móvil	Solución MDM autoalojada para Android (edición comunitaria; verificar).	Microsoft Intune u otra solución SaaS.	Inscribir al menos un dispositivo; demostrar bloqueo, cifrado y borrado remoto.
DLP	GPO de almacenamiento extraíble, FSRM (clasificación y filtrado de archivos), integridad de archivos en Wazuh, BitLocker.	Microsoft Purview DLP.	Documentar el alcance real: DLP básico de endpoint y servidor de archivos.
EDR/XDR	Agente Wazuh (detección, integridad, respuesta activa) y Microsoft Defender Antivirus por GPO.	Defender for Endpoint.	Distinguir antivirus, EDR y XDR en la discusión 10.4.

5.2.8 Pruebas del ambiente

Con el ambiente construido, el siguiente paso es comprobar que los controles funcionan. Cada prueba enlaza un riesgo y un control con un resultado verificable. La columna «Resultado obtenido» se llenará solo con lo que efectivamente ocurra, acompañado de su evidencia; si una prueba falla, reportaremos el fallo y la corrección aplicada.

Tabla 10

Plantilla de pruebas (resultados a completar por el grupo)

ID	Prueba	Riesgo y control	Resultado esperado	Resultado obtenido	Evidencia
PR-01	Desde Invitados y BYOD, conectar a DB01:5432	Movimiento lateral; A.8.22	Conexión bloqueada y registrada	[completar]	[EV-…]
PR-02	Escaneo de puertos desde la	Exposición; A.8.20	Solo 443 visible en la	[completar]	[EV-…]

ID	Prueba	Riesgo y control	Resultado esperado	Resultado obtenido	Evidencia
	Red NAT (WAN)		DMZ		
PR-03	Despliegue PXE de un cliente nuevo con WinPE	Configuración; A.8.9	Cliente instalado, unido al dominio y con GPO. Si el PXE con EFI falla: «PXE demostrado hasta WinPE; Windows 11 instalado desde ISO» = cumplimiento parcial	[completar]	[EV-…]
PR-04	Equipo desconocido arranca por PXE	Acceso no autorizado; A.5.15, A.8.2, A.8.9	Queda pendiente de aprobación	[completar]	[EV-…]
PR-05	Acceso VPN o bastión sin segundo factor	Robo de credenciales; A.8.5	Acceso rechazado	[completar]	[EV-…]
PR-06	Intentos fallidos repetidos de inicio de sesión	Fuerza bruta; A.8.16, A.8.5	Bloqueo de cuenta y alerta en Wazuh	[completar]	[EV-…]
PR-07	Tráfico de prueba benigno que dispara Suricata	Intrusión; A.8.16	Alerta visible en Suricata y Wazuh	[completar]	[EV-…]
PR-08	Copia de archivo a USB en cliente administrativo	Fuga de datos; A.8.12, A.7.10	Escritura bloqueada por GPO	[completar]	[EV-…]
PR-09	Restauración de AD y de la base de datos	Pérdida o ransomware; A.8.13	Restauración dentro del RTO y RPO del BIA	[completar]	[EV-…]
PR-10	Apagado de DC01 (si hay DC02)	Falla de servicio; A.8.14	Autenticación y DHCP continúan	[completar]	[EV-…]
PR-11	Bloqueo y borrado remoto de MOB01	Pérdida del dispositivo; A.8.1	Comando ejecutado y registrado	[completar]	[EV-…]
PR-12	Desde Invitados: resolver zonas DNS internas y	Reconocimiento y movimiento lateral;	Sin resolución interna ni conexión	[completar]	[EV-…]

ID	Prueba	Riesgo y control	Resultado esperado	Resultado obtenido	Evidencia
	conectar a 10.20.30.0/24 y al bastión	A.8.22, A.8.21			

5.2.9 Tabla de diseñado frente a implementado

Esta tabla es obligatoria en el E2 y en el capítulo de Resultados (sección 9 del enunciado). Estados posibles: Implementado, Implementado parcialmente, Simulado en laboratorio, Diseñado (no implementado). En ella justificamos también las diferencias de plataforma entre el diseño institucional y el laboratorio.

Tabla 11

Plantilla de componentes diseñados frente a implementados

Componente del diseño	Equivalente en el laboratorio	Estado	Evidencia	Diferencias y justificación
Plataforma de virtualización de producción	Oracle VirtualBox (un solo hipervisor)	[completar]	[EV-…]	Si el diseño mantiene otra plataforma (por ejemplo un clúster de tres nodos), justificar aquí que el laboratorio usa VirtualBox por costo y disponibilidad.
Segmentación por VLAN (802.1Q)	Redes internas de VirtualBox + FW01	Simulado en laboratorio	[EV-…]	VirtualBox no ofrece troncales 802.1Q nativas; cada VLAN es una red interna.
VLAN 21 y 23	Ninguno (opcional)	[completar]	[EV-…]	Mismo patrón que la VLAN 20.
NGFW en alta disponibilidad (2 equipos)	FW01 (uno solo)	[completar]	[EV-…]	[completar]
IDS/IPS Suricata	Suricata en FW01	[completar]	[EV-…]	[completar]
AD DS y DNS redundantes	DC01 (+ DC02)	[completar]	[EV-…]	[completar]
Despliegue de equipos	WDS01 (PXE) + WinPE personalizado + DISM	[completar]	[EV-…]	Limitaciones de WDS y de PXE en VirtualBox (5.2.5).

Componente del diseño	Equivalente en el laboratorio	Estado	Evidencia	Diferencias y justificación
MFA	Opción elegida en 5.2.7	[completar]	[EV-…]	[completar]
SIEM, EDR y XDR	SIEM01 (Wazuh) y agentes	[completar]	[EV-…]	[completar]
MDM y DLP	MOB01, MDM elegido, GPO y FSRM	[completar]	[EV-…]	[completar]
Respaldo 3-2-1-1-0 (copia externa en nube en el diseño)	BKP01 + exportaciones de VM + copia en sitio DR o disco desconectado	[completar]	[EV-…]	Si el diseño usa almacenamiento de nube para la copia externa, aquí se declara que en el laboratorio se sustituye.
Nube pública (Azure, AWS o GCP)	Sitio DR simulado o ninguno	[completar]	[EV-…]	Pendiente de la confirmación escrita del docente (adjuntar).
Data Center TIA-942	No aplica en el laboratorio	Diseñado (no implementado)	Documental	Se documenta en el E7.

5.2.10 Registro de evidencias

Tabla 12

Plantilla del registro de evidencias

ID	Semana	Paso o prueba	Qué demuestra	Archivo	Responsable	Revisado sin secretos
EV-E2-P01-01	[n]	P01	[completar]	[nombre de archivo]	[integrante]	Sí / No

5.3 Fase 3. Modelo de gestión de seguridad (E3)

Con la infraestructura diseñada y el laboratorio en marcha, en esta fase se establece formalmente el modelo de seguridad de la Universidad Mariano Sanchez. El E3 debe incluir los 12 componentes de la sección 9 del enunciado y relacionarlos con las cláusulas 4 a 10 de ISO/IEC 27001:2022.

Tabla 13

Componentes del E3 y orientación

Componente (sección 9 del enunciado)	Qué documentar	Referencia
Alcance del SGSI	Procesos, sedes, servicios, sistemas y exclusiones justificadas.	ISO/IEC 27001, cl. 4.3
Contexto de la organización	Cuestiones internas y externas; partes interesadas y sus requisitos.	cl. 4.1 y 4.2
Activos	Remitir al E4.1, con criterios de clasificación.	A.5.9, A.5.12
Procesos críticos	Remitir al E4.2 (BIA).	ISO 22301 (ISO, 2019)
Gestión de riesgos	Metodología, escalas, criterios de aceptación y dueños del riesgo.	cl. 6.1; ISO/IEC 27005 (ISO e IEC, 2022c); NIST SP 800-30
Controles	Declaración de Aplicabilidad (SoA) sobre los 93 controles del Anexo A.	cl. 6.1.3; ISO/IEC 27002 (ISO e IEC, 2022b)
Políticas	Política general de seguridad y políticas temáticas (E5).	cl. 5.2; A.5.1
Zero Trust	Los 7 principios (tenets) de NIST SP 800-207 (sección 2.1) y sus componentes PE, PA y PEP aplicados al escenario (Tabla 14).	NIST SP 800-207
Gestión de incidentes	Respuesta a incidentes organizada según las funciones de CSF 2.0 (Gobernar, Identificar y Proteger como preparación; Detectar, Responder y Recuperar como respuesta), como propone SP 800-61 Rev. 3 (Nelson et al., 2025). Si se prefiere el ciclo clásico de preparación, detección y análisis, contención, erradicación y recuperación, y actividad posterior, citar SP 800-61 Rev. 2.	A.5.24 a A.5.28; NIST SP 800-61 Rev. 3 (verificar)

Componente (sección 9 del enunciado)	Qué documentar	Referencia
Continuidad	Remitir al E7.	A.5.29, A.5.30; ISO 22301
Gobierno de TI	Remitir al E6; roles y comités.	COBIT 2019
Gestión de servicios	Remitir al E6; catálogo y niveles de servicio.	ITIL 4

Tabla 14

Principios de Zero Trust (NIST SP 800-207, sección 2.1) aplicados al laboratorio

N.º	Principio (tenet)	Aplicación en el escenario
1	Todas las fuentes de datos y servicios de cómputo se consideran recursos.	Servidores, aplicaciones, BYOD y la base de datos figuran en el inventario E4.1 con dueño.
2	Toda comunicación se protege sin importar la ubicación en la red.	TLS hacia el portal y la base de datos; VPN cifrada; la LAN no se considera confiable.
3	El acceso a cada recurso se concede por sesión.	Sesiones de VPN y del bastión con MFA y tiempo de expiración.
4	El acceso se decide por política dinámica (identidad, aplicación, estado del dispositivo, atributos de comportamiento y del entorno).	Grupos de AD, cumplimiento MDM de MOB01 y reglas de FW01 por segmento.
5	Se monitorea y mide la integridad y postura de seguridad de todos los activos.	Agentes Wazuh (vulnerabilidades e integridad) y estado MDM.
6	La autenticación y autorización son dinámicas y se aplican estrictamente antes de cada acceso.	MFA en accesos privilegiados y remotos; modelo por niveles; LAPS.
7	Se recoge la mayor información posible sobre activos, red y comunicaciones para mejorar la postura.	Registros centralizados en SIEM01 y revisión periódica de alertas.

Nota. Componentes lógicos: punto de aplicación de políticas (PEP) = FW01, el bastión con MFA y PRX01; motor y administrador de políticas (PE y PA) = AD DS, el proveedor de MFA y la política de FW01; fuentes de datos = Wazuh y el MDM. Si se usa la formulación de Microsoft (verificar explícitamente, mínimo privilegio, asumir brecha), citarla aparte.

De manera complementaria, conviene incluir roles y responsabilidades (por ejemplo: alta dirección, responsable del SGSI, dueños de activos, TI, comité de seguridad), objetivos de seguridad medibles (cl. 6.2) y un perfil actual y objetivo de

NIST CSF 2.0 (funciones Gobernar, Identificar, Proteger, Detectar, Responder y Recuperar).

5.4 Fase 4. Implementación y gestión de riesgos (E4.1 a E4.6)

Esta fase es uno de los componentes principales del proyecto, pues reúne el 30 % de la rúbrica entre inventario, BIA y análisis de riesgos, más el 10 % del tratamiento. Las tablas muestran las columnas mínimas del enunciado, que el grupo llenará con sus propios datos. Por su ancho, la sección se presenta en páginas horizontales con letra de 12 puntos. Las escalas de 1 a 5 de C, I y D (5.4.1), del impacto del BIA (5.4.2) y de la matriz de riesgos (5.4.5) deben ser las mismas.

5.4.1 E4.1 Inventario de activos

Las 12 columnas mínimas no caben de forma legible en una sola tabla a 12 puntos; por eso las dividimos en dos tablas enlazadas por el identificador.

Tabla 15

Inventario de activos, parte A: identificación (punto 4.1 de la sección 9 del enunciado)

Identificador	Activo	Tipo	Propietario	Custodio	Ubicación	Información procesada
ACT-01	[completar]	[completar]	[completar]	[completar]	[completar]	[completar]

Tabla 16

Inventario de activos, parte B: valoración (punto 4.1 de la sección 9 del enunciado)

Identificador	Confidencialidad (1-5)	Integridad (1-5)	Disponibilidad (1-5)	Criticidad	Dependencias
ACT-01	[1-5]	[1-5]	[1-5]	[regla]	[ACT-xx]

Nota. Definir la regla de criticidad (por ejemplo, el máximo de C, I y D). Tipos sugeridos: información, software, hardware, servicio, persona, instalación. Incluir los activos del laboratorio (DC01, WDS01 y otros) y del diseño; WDS01 es un activo de Nivel 0.

5.4.2 E4.2 Business Impact Analysis (BIA)

Tabla 17

Estructura sugerida del BIA (punto 4.2 de la sección 9 del enunciado), parte A: impactos (escala 1-5)

Proceso	Operativo	Financiero	Reputacional	Legal o regulatorio	Académico o de negocio	Impacto a 4 h	a 24 h	a 72 h
PRC-01 [completar]	[1-5]	[1-5]	[1-5]	[1-5]	[1-5]	[1-5]	[1-5]	[1-5]

Tabla 18

Estructura sugerida del BIA, parte B: objetivos de recuperación

Proceso	MTPD	RTO	RPO	MBCO (capacidad mínima)	Recursos mínimos	Dependencias
PRC-01	[h]	[h]	[h]	[completar]	[completar]	[ACT-xx]

Nota. Reglas de coherencia: RTO ≤ MTPD; el RPO define la frecuencia mínima de respaldo; las dependencias (identidad, red, almacenamiento) deben tener un RTO menor o igual que el de los procesos que las usan. La evolución del impacto en el tiempo (4, 24 y 72 h) justifica el MTPD (ISO 22301, cl. 8.2.2). MBCO: capacidad mínima aceptable durante la interrupción. Los valores del borrador (por ejemplo, identidad con RTO de 4 h) son preliminares hasta completar el BIA.

5.4.3 E4.3 Matriz de análisis de riesgos (NIST SP 800-30)

Proceso de referencia de NIST SP 800-30 Rev. 1: preparar la evaluación; identificar fuentes y eventos de amenaza, vulnerabilidades y condiciones predisponentes; determinar probabilidad e impacto; determinar el riesgo; comunicar y mantener la evaluación.

Tabla 19

Columnas mínimas de la matriz de riesgos (punto 4.3 de la sección 9 del enunciado)

ID	Activo	Amenaza	Vulnerabilidad	Probabilidad	Impacto	Riesgo inherente	Controles existentes	Riesgo residual
R-01	[ACT-xx]	[completar]	[completar]	[1-5]	[1-5]	[P×I y nivel]	[CTL-xx]	[P×I y nivel]

Además de los riesgos de la universidad, deben registrarse los del propio laboratorio: obsolescencia anunciada del rol WDS; despliegue desatendido deshabilitado desde abril de 2026 por CVE-2026-0386 (y el riesgo de reactivarlo); uso de Windows 10 sin soporte, si se elige; VirtualBox como plataforma sin soporte oficial de Microsoft para WDS y chipset ICH9 experimental.

5.4.4 E4.4 Evaluación OCTAVE

Se sugiere OCTAVE Allegro (Caralli et al., 2007), cuyos ocho pasos son: (1) establecer criterios de medición del riesgo; (2) desarrollar el perfil del activo de información; (3) identificar sus contenedores; (4) identificar áreas de preocupación; (5) identificar escenarios de amenaza; (6) identificar riesgos; (7) analizar riesgos; y (8) seleccionar el enfoque de mitigación. En el E4.4 explicaremos la metodología utilizada, los activos críticos, las amenazas, los escenarios de riesgo, la evaluación y los resultados.

- Usar como anexo las hojas de trabajo del informe CMU/SEI-2007-TR-012 (o equivalentes propias): criterios de medición del riesgo, perfil del activo, mapa de entorno (contenedores), árboles de amenaza y hoja de riesgos.
- Paso 1: priorizar las áreas de impacto (reputación, financiera, productividad, seguridad y salud, multas o sanciones legales) y añadir un área «académica» propia del escenario.
- Paso 3: tipificar los contenedores como técnicos (por ejemplo DC01, WDS01, DB01), físicos (Data Center, archivos en papel) y personas (registro académico, TI).
- Paso 7: calcular la puntuación relativa del riesgo = Σ (valor de impacto en cada área × prioridad del área).
- Cruce con la matriz NIST: el mismo riesgo conserva el mismo identificador R-xx en el E4.3, el E4.4 y el E4.6.

5.4.5 E4.5 Matriz de calor

El enunciado exige como mínimo Probabilidad × Impacto y criterios claros de clasificación (ISO/IEC 27001, cl. 6.1.2; ISO/IEC 27005). Escalas propuestas (ajustables por el grupo, pero las mismas en todo el documento):

Tabla 20

Escalas de probabilidad e impacto (1 a 5)

Valor	Probabilidad: descriptor	Probabilidad: frecuencia orientativa	Impacto: descriptor	Impacto: criterio académico y económico orientativo
1	Rara	Menos de una vez en 5 años	Insignificante	Sin efecto en clases ni en registros; costo despreciable
2	Improbable	Una vez en 2 a 5 años	Menor	Molestias puntuales; se recupera en horas
3	Posible	Una vez al año	Moderado	Afecta a un servicio o a una facultad por un día
4	Probable	Varias veces al año	Mayor	Interrumpe matrícula, exámenes o pagos; exposición de datos limitada
5	Casi segura	Mensual o más	Catastrófico	Pérdida o alteración de expedientes, filtración masiva o sanción legal

Niveles: Bajo 1 a 4; Medio 5 a 9; Alto 10 a 16; Crítico 17 a 25 (con valores enteros solo se alcanzan 20 y 25). Regla adicional: toda celda con impacto 5 se clasifica como mínimo Alto, para que un evento catastrófico poco probable no quede como Medio.

Tabla 21

Matriz de calor 5×5 (criterios propuestos; los riesgos se ubican con su ID)

Probabilidad / Impacto	I = 1	I = 2	I = 3	I = 4	I = 5
P = 5	5 Medio	10 Alto	15 Alto	20 Crítico	25 Crítico
P = 4	4 Bajo	8 Medio	12 Alto	16 Alto	20 Crítico
P = 3	3 Bajo	6 Medio	9 Medio	12 Alto	15 Alto
P = 2	2 Bajo	4 Bajo	6 Medio	8 Medio	10 Alto
P = 1	1 Bajo	2 Bajo	3 Bajo	4 Bajo	5 Alto

Nota. Verde: bajo; amarillo: medio; naranja: alto; rojo: crítico. Mostrar dos matrices: riesgo inherente y riesgo residual.

Tabla 22

Acción, plazo y aprobación por nivel de riesgo (apetito de riesgo propuesto)

Nivel	Acción	Plazo	Quién aprueba o acepta
Bajo	Aceptar y monitorear	Revisión anual	Dueño del activo
Medio	Tratar o aceptar de forma justificada	Plan en 90 días	Dueño del riesgo, con firma (aceptación formal)
Alto	Tratar obligatoriamente; no se acepta sin tratamiento	Plan en 30 días	Responsable del SGSI y comité de seguridad
Crítico	Tratamiento inmediato y medidas temporales	Inicio en 7 días	Rectoría o alta dirección

Nota. Umbral de aceptación propuesto: solo se aceptan riesgos Bajos, y Medios con la firma del dueño del riesgo. Ajustar con la dirección de la universidad ficticia y declararlo en el E3.

5.4.6 E4.6 Plan de tratamiento de riesgos

Tabla 23

Columnas mínimas del plan de tratamiento (punto 4.6 de la sección 9 del enunciado)

Riesgo	Tratamiento	Control	Responsable	Prioridad	Plazo	Estado	Riesgo residual esperado
R-01	Mitigar, evitar, transferir o aceptar	[CTL-xx, A.x.x]	[rol]	[nivel]	[semana]	[estado]	[P×I y nivel]

Nota. Cada riesgo debe tener una estrategia. Aceptar requiere la firma de quien corresponda según la tabla anterior; transferir debe indicar a quién (por ejemplo, un seguro o un proveedor).

5.5 Fase 5. Políticas, controles y buenas prácticas (E5)

Una vez tratados los riesgos, corresponde traducir el tratamiento en políticas y controles. El enunciado fija seis bloques de políticas mínimas. Cada política debe tener objetivo, alcance, responsables, lineamientos, excepciones, cumplimiento y revisión, y debe enlazarse con riesgos y controles. Cabe señalar que, en el laboratorio, varias políticas se demuestran con GPO de AD DS (evidencia del E2).

Tabla 24

Bloques de políticas mínimas exigidos en la Fase 5 (sección 9 del enunciado)

Bloque	Políticas mínimas	Implementación sugerida en el laboratorio
Dominio e identidad	Administración de identidades; autenticación; autorización; MFA; privilegios.	Ciclo de vida de cuentas en AD DS; RBAC por grupos; cuentas administrativas separadas; MFA en accesos privilegiados.
Grupos	Administradores; usuarios; personal académico; personal administrativo; terceros.	Grupos de seguridad y UO por perfil; cuentas de terceros con vencimiento.
Equipos	Hardening; gestión de parches; EDR; cifrado; control de aplicaciones.	Línea base (por ejemplo CIS Benchmarks); actualizaciones; agente Wazuh; BitLocker; AppLocker o WDAC.
Usuarios	Contraseñas; MFA; mínimo privilegio; acceso remoto; uso aceptable.	GPO de contraseñas y bloqueo; VPN con MFA; aviso de uso aceptable al iniciar sesión.
Nube	Control de acceso; configuración segura; segmentación; registro; monitoreo.	Si no hay nube implementada: política para el diseño y el sitio DR; registro y monitoreo del túnel.
Dispositivos móviles	MDM; DLP; cifrado; bloqueo; borrado remoto; BYOD.	MDM con perfiles para equipos institucionales y BYOD; VLAN 25; cifrado obligatorio; bloqueo y borrado remoto.

Entregables: E5.1 Políticas de seguridad; E5.2 Matriz de controles; E5.3 Documento de buenas prácticas. Cada control debe relacionarse con el riesgo que pretende tratar.

Tabla 25

Plantilla de la matriz de controles (E5.2)

ID control	Control (Anexo A)	Riesgos que trata	Política	Implementación	Estado	Evidencia	Indicador
CTL-01	[A.x.x nombre]	[R-xx]	[POL-xx]	[técnica o administrativa]	[estado]	[EV-xx]	[métrica]

Nota. Matriz en página horizontal para mantener la letra de 12 puntos.

5.6 Fase 6. Gobernanza y gestión de servicios de TI (E6)

Por otro lado, el proyecto no se limita a lo técnico: el grupo debe aplicar COBIT 2019 e ITIL 4 a la Universidad Mariano Sanchez. Las tablas 26 y 27 proponen objetivos y prácticas pertinentes, que deberemos verificar contra las publicaciones oficiales.

Tabla 26

Aspectos de COBIT 2019 exigidos y objetivos sugeridos

Aspecto (sección 9 del enunciado)	Objetivos COBIT 2019 sugeridos (verificar)	Producto esperado
Gobierno	EDM01 Asegurar el establecimiento y mantenimiento del marco de gobierno	Comité de seguridad y TI; estructura de decisiones.
Gestión de riesgos	EDM03 Asegurar la optimización del riesgo; APO12 Riesgo gestionado	Apetito de riesgo; vínculo con el E4.
Cumplimiento	MEA03 Cumplimiento gestionado de requisitos externos	Registro de requisitos legales y contractuales.
Alineamiento estratégico	EDM02 Entrega de beneficios; APO02 Estrategia gestionada	Objetivos de TI alineados con la misión académica.
Gestión de recursos	EDM04 Optimización de recursos; APO07 Recursos humanos	Plan de capacidades, personal y presupuesto.
Desempeño	MEA01 Supervisión del desempeño y la conformidad	Indicadores (KPI y KRI) y tablero.
Seguridad (complementario)	APO13 Seguridad gestionada; DSS05 Servicios de seguridad gestionados; DSS04 Continuidad gestionada	Vínculo explícito con el SGSI y el E7.
Servicios y operación (complementario)	APO09 Acuerdos de servicio gestionados; BAI06 Cambios de TI gestionados; BAI09 Activos gestionados; BAI10 Configuración gestionada; DSS02 Peticiones de servicio e incidentes gestionados; DSS03 Problemas gestionados	Cruce 1 a 1 con las prácticas de ITIL 4 (Tabla 27); sirve para la pregunta 10.6.

Nota. Para cada objetivo, indicar el nivel de capacidad actual y objetivo (0 a 5) y mencionar el área de enfoque de seguridad de la información de COBIT 2019 (verificar el título exacto de la publicación).

Tabla 27

Prácticas de ITIL 4 exigidas (nombres oficiales en inglés) y su cruce con COBIT 2019

Práctica de ITIL 4	Aplicación sugerida en el escenario	Objetivo COBIT relacionado
Incident management (gestión de incidentes)	Clasificación y prioridad; integración con las alertas del SIEM; tiempos de atención.	DSS02
Change enablement (habilitación de cambios; «change control» en la edición 2019 de Foundation, verificar)	Cambios estándar, normales y de emergencia; cambios al diagrama aprobado y a las GPO.	BAI06
Problem management (gestión de problemas)	Análisis de causa raíz de incidentes recurrentes; errores conocidos.	DSS03
Service level management (gestión de niveles de servicio)	Acuerdos de nivel de servicio para LMS, matrícula e identidad, coherentes con el RTO.	APO09
IT asset management (gestión de activos de TI)	Ciclo de vida de activos enlazado con el E4.1.	BAI09
Service configuration management (gestión de la configuración del servicio)	Base de configuración (CMDB) con relaciones; WDS01 e imágenes WinPE como elementos de configuración.	BAI10
Service continuity management (gestión de la continuidad del servicio)	Vínculo con el BCP y el DRP del E7.	DSS04
Information security management (gestión de la seguridad de la información)	Vínculo con el SGSI y las políticas del E5.	APO13, DSS05
Monitoring and event management (complementaria)	Eventos de Wazuh y Suricata clasificados como informativos, advertencias o excepciones.	DSS01, DSS05
Service desk (complementaria)	Punto único de contacto para reportar incidentes y solicitudes.	DSS02

Productos recomendados del E6: matriz RACI, catálogo de servicios, procedimientos breves de incidentes y cambios, e indicadores.

5.7 Fase 7. Continuidad del negocio y Data Center (E7)

5.7.1 Continuidad

El E7 debe desarrollar: estrategia de continuidad, BCP, DRP, RTO, RPO, procedimientos de recuperación, roles y responsabilidades, y pruebas de recuperación (ISO 22301; NIST SP 800-34 como apoyo [Swanson et al., 2010]). En ese sentido, la prueba de restauración del E2 (PR-09) es la evidencia técnica natural de las pruebas de recuperación. Además, proponemos un ejercicio de mesa (escenario de ransomware) con su acta.

5.7.2 Data Center (ANSI/TIA-942-C)

El Data Center, en cambio, no se construye en el laboratorio: se documenta como diseño de buenas prácticas para la sede de la Universidad Mariano Sanchez, indicando el nivel de clasificación objetivo de ANSI/TIA-942-C (2024) y su justificación según el BIA: Rated-1 (infraestructura básica), Rated-2 (componentes redundantes), Rated-3 (mantenible de forma concurrente) o Rated-4 (tolerante a fallas). Los niveles «Rated» de TIA no equivalen a los «Tier» del Uptime Institute, que son un esquema distinto de certificación.

Tabla 28

Elementos de Data Center exigidos en el punto 7.2 de la sección 9 del enunciado y controles del Anexo A

Elemento	Buena práctica a documentar	Vínculo
Energía	Acometida, tableros, distribución y redundancia (N, N+1, 2N).	RTO de servicios críticos
UPS	Autonomía para operar o apagar ordenadamente; mantenimiento y pruebas.	A.7.11, A.7.8, A.7.13
Generadores	Autonomía, combustible, transferencia automática y pruebas periódicas.	A.7.11, A.7.8, A.7.13
Climatización	Pasillos fríos y calientes, redundancia y monitoreo de temperatura y humedad.	A.7.5, A.7.11
Cableado	Estructurado, etiquetado, rutas separadas y documentado.	A.7.12
Redundancia	Componentes duplicados y rutas alternas según el nivel objetivo.	A.8.14
Seguridad física	Perímetros, zonas y vigilancia.	A.7.1, A.7.4
Control de acceso	Tarjeta o biometría, registro de visitantes y acompañamiento.	A.7.2, A.7.3
Protección contra incendios	Detección temprana y supresión con agente limpio.	A.7.5
Monitoreo	Sensores ambientales y de energía integrados con alertas.	A.7.4, A.8.16

Elemento	Buena práctica a documentar	Vínculo
Resiliencia	Sitio alterno, pruebas y mejora continua.	A.5.30; ISO 22301

6. Discusión académica: las 6 preguntas obligatorias

Además de los entregables técnicos, el documento final debe incluir una discusión académica entre los integrantes del grupo que responda las seis preguntas de la sección 10 del enunciado, sustentada en fuentes académicas, técnicas o normativas confiables. Nuestra intención es que cada respuesta relacione la teoría con decisiones concretas del proyecto y del laboratorio, y que cite al menos dos fuentes.

Tabla 29

Preguntas de la sección 10 del enunciado y orientación

N.º	Pregunta (sección 10 del enunciado)	Orientación para el grupo
10.1	Zero Trust: ¿cuáles son las principales diferencias y consideraciones al implementar Zero Trust en un entorno de nube pública frente a un entorno híbrido?	Usar NIST SP 800-207; contrastar con la decisión local y el diseño híbrido (identidad, segmentación, bastión, VPN).
10.2	MDM y DLP: ¿cuáles son las principales buenas prácticas para proteger la información institucional mediante MDM y DLP en dispositivos móviles?	BYOD frente a dispositivos institucionales; contenedores de trabajo; privacidad del usuario; lo probado con MOB01.
10.3	Cumplimiento: ¿qué consideraciones adicionales deben tomarse en cuenta para cumplir con las normativas locales e internacionales relacionadas con la seguridad de la información y la computación en la nube?	Marco guatemalteco aplicable (verificar vigencia), ubicación de datos, contratos con proveedores; ISO/IEC 27017 y 27018.
10.4	SIEM, EDR y XDR: ¿cuál es su contribución a la detección y respuesta ante incidentes en comparación con mecanismos tradicionales?	Comparar con antivirus y firewall tradicionales; apoyarse en lo observado con Wazuh y Suricata.
10.5	ISO/IEC 27001: ¿cómo puede mantenerse la mejora continua del SGSI después de una eventual certificación?	Cláusulas 9 y 10: auditorías internas, revisión por la dirección, acciones correctivas, indicadores; ISO 19011.
10.6	COBIT e ITIL: ¿cómo pueden complementarse COBIT 2019 e ITIL	COBIT como gobierno (qué y por qué) e ITIL como gestión de

N.º	Pregunta (sección 10 del enunciado)	Orientación para el grupo
	4 para alinear la seguridad de la información y la gestión de TI con los objetivos organizacionales?	servicios (cómo); ejemplo con incidentes y cambios.

7. Estructura del documento final y contenido mínimo de Resultados

7.1 Estructura obligatoria (sección 11 del enunciado)

Tabla 30

Estructura del documento final

Parte	Contenido sugerido
Portada	UMG, facultad, maestría, curso, docente, título del proyecto, Grupo 3, seis integrantes con carné, lugar y año.
Tabla de contenido	Generada automáticamente a partir de los títulos.
1. Introducción	Contexto, problema, objetivos general y específicos (secciones 6 y 7 del enunciado), alcance y estructura del documento.
2. Marco teórico	Estándares de la sección 8 del enunciado aplicados al proyecto (no definiciones aisladas).
3. Metodología	Enfoque basado en riesgos, fases, herramientas, decisión de construcción local con WDS (con la confirmación del docente), criterios de evaluación.
4. Resultados	Los 20 puntos mínimos de la sección 12 del enunciado (Tabla 31, apartado 7.2 de esta guía).
5. Discusión	Las 6 preguntas de la sección 10 del enunciado.
6. Conclusiones	Respuestas a los objetivos; limitaciones del laboratorio; trabajo futuro.
7. Referencias	APA 7, en orden alfabético y con sangría francesa.
8. Anexos	Diagramas en alta resolución, registro de evidencias, configuraciones exportadas sin secretos, confirmación del docente, actas, declaración de uso de IA.

7.2 Los 20 puntos obligatorios de Resultados (sección 12 del enunciado)

Tabla 31

Puntos mínimos del capítulo de Resultados

N.º	Punto (sección 12 del enunciado)	Proviene de	Estado en el borrador actual
1	Descripción del escenario	E1	Parcial (Fase 1, apartado 1; ampliar)
2	Alcance del SGSI	E3	Pendiente

N.º	Punto (sección 12 del enunciado)	Proviene de	Estado en el borrador actual
3	Diagrama de infraestructura	E1	Parcial (no coincide con la tabla de VLAN)
4	Explicación de la arquitectura	E1	Parcial (componentes y justificación)
5	Inventario de activos	E4.1	Pendiente
6	BIA	E4.2	Pendiente
7	Análisis de riesgos	E4.3	Pendiente
8	Evaluación OCTAVE	E4.4	Pendiente
9	Matriz de calor	E4.5	Pendiente
10	Plan de tratamiento	E4.6	Pendiente
11	Políticas de seguridad	E5.1	Pendiente
12	Matriz de controles	E5.2	Pendiente
13	Buenas prácticas	E5.3	Pendiente
14	Zero Trust	E1, E3, E5	Mencionado en la justificación
15	MDM/DLP	E2, E5	Solo una fila en controles
16	SIEM/EDR/XDR	E1, E2	Mencionado (Wazuh y Suricata)
17	Implementación tecnológica	E2	Pendiente (Fase 2 local con WDS)
18	Continuidad y recuperación	E7	Parcial (estrategia inicial)
19	COBIT/ITIL	E6	Pendiente
20	Data Center	E7	Pendiente

Nota. En el borrador actual el capítulo de Resultados solo enumera estos puntos, sin contenido.

8. Formato obligatorio (sección 14 del enunciado)

Para que sirva también de plantilla, este mismo documento aplica el formato obligatorio.

Tabla 32

Formato obligatorio y su aplicación

Elemento	Requisito (sección 14 del enunciado)	Cómo se aplica en Word
Papel	Tamaño carta; una sola cara cuando corresponda.	Disposición > Tamaño > Carta (21.59 × 27.94 cm).
Tipografía	Arial, 12, estilo normal.	Estilo Normal en Arial 12; títulos en Arial 12 negrita; tablas también en 12. Las tablas anchas van en páginas horizontales (sección propia con la numeración continua) o se dividen en dos.

Elemento	Requisito (sección 14 del enunciado)	Cómo se aplica en Word
Interlineado	1.0 en el cuerpo.	Párrafo > Interlineado: Sencillo.
Sangría	Primera línea de aproximadamente cinco espacios.	Párrafo > Especial: Primera línea, 1.27 cm.
Márgenes	Izquierdo 3.5 cm; derecho 2.5 cm; superior 3 cm; inferior 3 cm.	Márgenes personalizados.
Numeración	Arábiga, esquina superior derecha, en todas las páginas excepto portada y tabla de contenido.	Salto de sección después de la tabla de contenido; encabezado desvinculado; número de página a la derecha, iniciando en 1 en el capítulo 1 (pendiente de confirmar; ver apartado 13 de esta guía).
Referencias	APA 7.ª edición, versión en español cuando corresponda.	Orden alfabético, sangría francesa; citas autor-año en el texto. APA aplica a citas y referencias.

9. Rúbrica de evaluación (sección 16 del enunciado)

Tabla 33

Rúbrica sobre 20 puntos del proyecto final, con puntos por nivel

Criterio	Peso	Puntos	Excelente 90-100 %	Satisfactorio 80-89 %	En desarrollo 70-79 %	Insuficiente < 70 %
Diseño de infraestructura y arquitectura	15 %	3	2.7 a 3	2.4 a 2.67	2.1 a 2.37	< 2.1
Construcción/implementación del ambiente	10 %	2	1.8 a 2	1.6 a 1.78	1.4 a 1.58	< 1.4
Inventario de activos	5 %	1	0.9 a 1	0.8 a 0.89	0.7 a 0.79	< 0.7
BIA	10 %	2	1.8 a 2	1.6 a 1.78	1.4 a 1.58	< 1.4
Análisis y evaluación de riesgos	15 %	3	2.7 a 3	2.4 a 2.67	2.1 a 2.37	< 2.1
Plan de tratamiento y controles	10 %	2	1.8 a 2	1.6 a 1.78	1.4 a 1.58	< 1.4
Políticas, Zero Trust, MDM/DLP y seguridad	10 %	2	1.8 a 2	1.6 a 1.78	1.4 a 1.58	< 1.4
Gobierno y gestión de servicios: COBIT/ITIL	5 %	1	0.9 a 1	0.8 a 0.89	0.7 a 0.79	< 0.7
Continuidad, recuperación y Data Center	5 %	1	0.9 a 1	0.8 a 0.89	0.7 a 0.79	< 0.7
Discusión y análisis crítico	5 %	1	0.9 a 1	0.8 a 0.89	0.7 a 0.79	< 0.7
Calidad del documento, referencias y APA	5 %	1	0.9 a 1	0.8 a 0.89	0.7 a 0.79	< 0.7
Suma de los criterios listados	95 %	19				

Nota. Puntos = peso × 20. Los rangos por nivel son una conversión aritmética de los porcentajes de la sección 16 del enunciado para orientar la autoevaluación; el docente asigna la nota.

Inconsistencia detectada. Los pesos listados en la sección 16 del enunciado suman **95 %** (19 puntos), aunque el enunciado indica «TOTAL 100 %». Falta un 5 % (1 punto) sin criterio asignado. Conviene consultarlo con el docente.

Tabla 34

Niveles de desempeño (sección 16 del enunciado)

Nivel	Descripción
Excelente (90-100 %)	Solución integral, coherente y técnicamente fundamentada; trazabilidad entre activos, procesos, riesgos, controles y resultados; implementaciones respaldadas por evidencias suficientes; estándares aplicados de forma pertinente.
Satisfactorio (80-89 %)	Cumple los principales requisitos con una solución funcional y coherente, con oportunidades de mejora en profundidad técnica, integración de estándares, evidencias o justificación.
En desarrollo (70-79 %)	Presenta los componentes principales, pero con inconsistencias, información incompleta, aplicación superficial de estándares o evidencias insuficientes.
Insuficiente (< 70 %)	Incumplimientos significativos, ausencia de componentes fundamentales, falta de coherencia entre fases o evidencia insuficiente de desarrollo e implementación.

10. Reglas del proyecto

10.1 Evidencias (sección 15 del enunciado)

Las evidencias pueden incluir diagramas, capturas de configuración, tablas, matrices, configuraciones de infraestructura y evidencias de IAM, MFA, segmentación, monitoreo, SIEM, EDR, MDM, DLP, backup y recuperación, resultados de pruebas y evidencias de controles. En todos los casos, cada evidencia debe estar identificada y relacionada con el elemento del proyecto que pretende demostrar.

- Cada captura lleva número de figura, identificador EV-xx, qué demuestra y a qué control o prueba corresponde.
- No incluir contraseñas, tokens, claves, secretos, datos personales reales ni información confidencial de terceros. Usar datos ficticios y difuminar lo sensible antes de pegar la captura.
- Las capturas deben ser del propio laboratorio del grupo, sin edición que altere su contenido.

10.2 Originalidad (sección 17 del enunciado)

Se considera falta académica: presentar como propio material de terceros; copiar proyectos publicados en Internet; usar proyectos de otros estudiantes sin autorización; fabricar evidencias de implementación; alterar capturas o resultados para aparentar una implementación inexistente; y presentar información técnica que no pueda sustentarse en la defensa. Por lo mismo, toda idea, modelo, imagen, tabla, código o documento de terceros debe citarse.

10.3 Uso de inteligencia artificial (sección 18 del enunciado)

La IA generativa puede usarse como apoyo (ideas iniciales, investigación, redacción, ortografía y gramática, ejemplos conceptuales, estructuras o tablas) con transparencia, responsabilidad y autoría. Cada integrante es responsable de verificar la información, validar las referencias, comprender los conceptos, comprobar las configuraciones, validar los resultados y defender oralmente el contenido. **No se debe usar IA para fabricar evidencias, resultados, pruebas de implementación ni referencias inexistentes.** Si el docente lo solicita, declararemos las herramientas de IA usadas y su propósito, por lo que conviene preparar esa declaración como anexo. Cabe señalar que esta guía fue elaborada con apoyo de IA y debe revisarse antes de usarse.

10.4 Presentación y defensa (sección 19 del enunciado)

Duración aproximada de 15 a 25 minutos (según el número de grupos), seguida de una pregunta técnica por grupo. La presentación debe incluir como mínimo estos 14 elementos de la sección 19 del enunciado:

1. Organización y problema identificado.
2. Objetivos.
3. Arquitectura.
4. Principales activos.
5. BIA.
6. Principales riesgos.
7. Matriz de riesgos.
8. Controles seleccionados.
9. Implementación.
10. Evidencias.
11. Continuidad.
12. Gobierno de TI.
13. Resultados.
14. Conclusiones.

El docente puede preguntar sobre decisiones de arquitectura, riesgos identificados, justificación de controles, aplicación de estándares, configuración tecnológica, resultados, continuidad y gobierno de TI. **Cada integrante debe demostrar conocimiento total del proyecto**, incluido el laboratorio WDS en VirtualBox.

Como somos seis integrantes, sugerimos repartir la exposición en bloques de unos 3 minutos por persona en 20 minutos: escenario y objetivos; arquitectura y segmentación; implementación y evidencias; activos y BIA; riesgos y tratamiento; controles, gobierno, continuidad y conclusiones. De esta forma, y ensayando respuestas cruzadas, nadie dependerá de un solo experto.

11. Asignación del grupo y observaciones al borrador

11.1 Asignación de los entregables de la Fase 1

Tabla 35

Asignación acordada para el E1

Integrante	Carné	Apartado del E1	Contenido mínimo esperado
Kevin Miguel Escot Soto	1593-16-9744	1. Descripción de la organización	Tamaño, estructura, sedes, procesos críticos, usuarios y actores, servicios, necesidades de seguridad, incluidos BYOD y móviles.
Kevin Miguel Escot Soto	1593-16-9744	6. Controles de seguridad	Control por riesgo con su ID del Anexo A y la prueba de verificación.
Paulino Josué Arrecis Rivera	1593-17-2874	2. Diseño y diagrama (topología)	Diagrama único y coherente con la tabla de VLAN; leyenda de diseñado e implementado.
Paulino Josué Arrecis Rivera	1593-17-2874	4 y 5. Flujos de comunicación y segmentación	Matriz de flujos (origen, destino, puerto, regla) y tabla de VLAN; incluir WDS (PXE) y BYOD.
Hector Rodrigo Sanchez Garcia	1593-20-12173	3. Descripción de componentes	Componentes con una sola tecnología elegida por función, alineados con el laboratorio local.
Erick Neftalí Molina Serech	1593-11-3388	7. Mecanismos de redundancia	Redundancia por capa y relación con la HA y el DR; qué se probará.
Jose Jovani Idelfonso	1593-13-21657	8. Estrategia inicial de continuidad	Estrategia, escenarios, RTO y RPO preliminares, activación y roles.
Gustavo Adolfo Delgado Quevedo	1593-12-10445	9. Justificación técnica	Por qué cada tecnología, qué riesgo reduce y alternativas descartadas; completar 9.2 a 9.4.

Nota. Fuente: reparto del grupo y Cronograma.xlsx. Introducción, marco teórico y metodología se completan en la semana siguiente, según el acuerdo del grupo.

11.2 Observaciones al borrador actual (ProyectoFinal.docx)

1. **Falta BYOD, MDM y DLP móvil.** El enunciado exige soporte para dispositivos móviles (sección 4 del enunciado) y políticas de MDM, DLP y BYOD (Fase 5

de la sección 9 del enunciado); el borrador solo los menciona en una fila de la tabla de controles. Agregar el segmento BYOD, la solución MDM, el flujo de inscripción y los controles DLP.

2. **Nombre del escenario.** Reemplazar «Universidad "Nombre"» (Descripción de componentes) y «universidad tecnológica» (Estrategia de continuidad) por «Universidad Mariano Sanchez», nombre acordado por el grupo, y usarlo de forma consistente en todo el documento.
3. **El diagrama no coincide con la tabla de VLAN.** El diagrama repite la VLAN 30 (Aplicaciones y Directorio), agrupa las VLAN 20 a 23 en «16 switches de acceso» sin identificarlas, conecta los switches de núcleo directamente a todas las VLAN (contradice la regla de forzar el tráfico entre VLAN por el NGFW) y no muestra móviles ni BYOD. Unificar diagrama, tabla de VLAN y matriz de flujos.
4. **Afirmación sobre Hetzner.** La justificación dice que la integración Suricata-Wazuh «se probó en el laboratorio previo de Hetzner». No hay evidencia en el proyecto y Hetzner no es una de las plataformas autorizadas (sección 5 del enunciado). Eliminarla o sustituirla por la prueba PR-07 del laboratorio, cuando exista.
5. **Falta el mapeo al Anexo A.** El borrador afirma que la arquitectura «se fundamenta» en ISO/IEC 27001 y 27002, pero ningún control cita su identificador (por ejemplo A.8.22 Segregación de redes). Agregar la columna Anexo A a la tabla de controles y preparar la SoA.
6. **Tecnologías mezcladas.** El borrador alterna dos hipervisores, PostgreSQL o SQL Server, NAS o SAN, y dos destinos de respaldo (un servidor de respaldo propio del hipervisor y almacenamiento de nube). Elegir una opción por función. El laboratorio usa VirtualBox (decisión del grupo); si el diseño de producción conserva otra plataforma o la copia en la nube, justificarlo en la tabla de diseñado frente a implementado (5.2.9). Revisar las dependencias de Entra ID y Azure si la nube queda solo en el diseño.
7. **Secciones vacías.** Introducción, Marco teórico, Metodología, Discusión, Conclusiones, Referencias y Anexos no tienen contenido; Resultados solo enumera los 20 puntos; los apartados 9.2 a 9.4 del borrador solo tienen título; el diagrama no tiene explicación, numeración ni fuente.
8. **Otros ajustes.** La portada lista solo 3 de los 6 integrantes y sin carné; quitar los nombres de los responsables de los títulos («(Kevin)») en la versión final; numerar tablas y figuras según APA; los RTO y RPO deben presentarse como preliminares hasta completar el BIA; actualizar Cronograma.xlsx (7 semanas y «sin implementación»).

12. Lista de verificación final (sección 20 del enunciado)

Antes de la entrega revisaremos esta lista y marcaremos cada punto solo cuando exista la evidencia o la sección correspondiente.

Tabla 36

Lista de verificación del estudiante

Hecho	Bloque	Verificación (sección 20 del enunciado)
[ ]	Organización	El sector seleccionado corresponde a uno de los sectores autorizados.
[ ]	Organización	La organización está claramente descrita.
[ ]	Organización	Se identificaron los procesos críticos.
[ ]	Organización	Se identificaron los usuarios y actores.
[ ]	Arquitectura	Se seleccionó una arquitectura autorizada (ver apartado 2.1 de esta guía: confirmación escrita).
[ ]	Arquitectura	Se justificó la arquitectura.
[ ]	Arquitectura	El diagrama está completo.
[ ]	Arquitectura	Se identificaron las zonas de seguridad.
[ ]	Arquitectura	Se identificó la segmentación.
[ ]	Arquitectura	Se incorporaron mecanismos de redundancia.
[ ]	Arquitectura	Se documentaron los flujos de comunicación.
[ ]	Riesgos	Se elaboró el inventario de activos.
[ ]	Riesgos	Se realizó el BIA.
[ ]	Riesgos	Se identificaron amenazas.
[ ]	Riesgos	Se identificaron vulnerabilidades.
[ ]	Riesgos	Se realizó el análisis de riesgos.
[ ]	Riesgos	Se aplicó OCTAVE.
[ ]	Riesgos	Se elaboró la matriz de calor.
[ ]	Riesgos	Se estableció el tratamiento de riesgos.
[ ]	Riesgos	Se determinó el riesgo residual.
[ ]	Seguridad	Se definió el modelo de seguridad de la información.
[ ]	Seguridad	Se establecieron políticas de seguridad.
[ ]	Seguridad	Se implementaron controles basados en ISO/IEC 27001 e ISO/IEC 27002.
[ ]	Seguridad	Se aplicaron principios de Zero Trust Architecture (ZTA).
[ ]	Seguridad	Se implementaron mecanismos de gestión de identidad y acceso (IAM).
[ ]	Seguridad	Se estableció autenticación multifactor (MFA).
[ ]	Seguridad	Se implementaron mecanismos de segmentación y control de acceso a la red.

Hecho	Bloque	Verificación (sección 20 del enunciado)
[ ]	Seguridad	Se implementó protección de endpoints mediante EDR y/o XDR.
[ ]	Seguridad	Se implementó monitoreo y correlación de eventos mediante SIEM.
[ ]	Seguridad	Se establecieron mecanismos de protección de datos mediante DLP.
[ ]	Seguridad	Se definieron controles para dispositivos móviles mediante MDM.
[ ]	Seguridad	Se establecieron políticas para usuarios, grupos, equipos y dispositivos.
[ ]	Seguridad	Se establecieron controles para la conectividad segura con la nube (o su justificación aprobada).
[ ]	Seguridad	Se establecieron controles para la conectividad segura de dispositivos móviles.
[ ]	Seguridad	Se definieron mecanismos de gestión y respuesta ante incidentes.
[ ]	Seguridad	Se establecieron mecanismos de respaldo y recuperación de información.
[ ]	Seguridad	Se documentaron las buenas prácticas aplicadas al escenario.
[ ]	Seguridad	Se presentaron evidencias de los controles implementados.

Además, recomendamos estas verificaciones adicionales: formato de la sección 14 del enunciado aplicado; 20 puntos de Resultados presentes; 6 preguntas de Discusión respondidas con fuentes; tabla de diseñado frente a implementado; ninguna captura con secretos; referencias APA verificadas; confirmación del docente adjunta; todos los integrantes ensayaron la defensa.

13. Preguntas abiertas y decisiones pendientes

1. Confirmación escrita del docente sobre la construcción local con WDS y sobre cómo se evaluará el requisito de nube híbrida (secciones 4, 5 y 20 del enunciado). Hasta recibirla, el enunciado prevalece.
2. Opción de cobertura híbrida (A, B o C del apartado 2.2 de esta guía) y plataforma de nube del diseño.
3. En qué equipo o equipos se instalará VirtualBox (memoria disponible) y si FW01 funcionará con el chipset ICH9 (experimental) o se aplica la opción 1 o la opción 2 del plan alterno (Tabla 6, apartado 5.2.3 de esta guía).
4. Si el arranque PXE con firmware EFI funciona en la versión de VirtualBox elegida; si no, demostrar PXE con BIOS e instalar Windows 11 desde ISO.

5. Herramienta de secuencia de instalación sobre WDS: WinPE propio con DISM (propuesta) o Configuration Manager (OSD). MDT queda descartado por su retiro.
6. Solución MFA, MDM y DLP elegida (local o con dependencia de nube).
7. Los pesos de la sección 16 del enunciado suman 95 %: ¿a qué criterio corresponde el 5 % restante?
8. ¿Aplican al proyecto el límite de 40 páginas y la coevaluación del 10 % de la guía didáctica?
9. ¿Acepta el docente páginas horizontales para tablas anchas? (Esta guía no reduce la letra por debajo de 12.)
10. Inicio de la numeración de páginas: esta guía reinicia en 1 en el capítulo 1 (Introducción); confirmar si el docente prefiere continuar la numeración real.

Referencias

Referencias en formato APA 7. Las normas ISO, IEC, TIA, ISACA y AXELOS (hoy parte de PeopleCert) son documentos de pago; NIST, SEI y CIS son de acceso abierto. Las entradas que no se validaron en línea llevan la marca «verificar versión» o «verificar fecha»: antes de citarlas en el informe final, confirmar en el enlace oficial la edición vigente, el año y el título exacto.

AXELOS. (2019). ITIL Foundation: ITIL 4 edition. TSO. https://www.axelos.com/

Caralli, R. A., Stevens, J. F., Young, L. R. y Wilson, W. R. (2007). Introducing OCTAVE Allegro: Improving the information security risk assessment process (CMU/SEI-2007-TR-012). Software Engineering Institute, Carnegie Mellon University. https://www.sei.cmu.edu/library/introducing-octave-allegro-improving-the-information-security-risk-assessment-process/

Center for Internet Security. (2021). CIS Critical Security Controls (versión 8). https://www.cisecurity.org/controls/v8

International Organization for Standardization. (2019). Security and resilience: Business continuity management systems: Requirements (ISO 22301:2019). https://www.iso.org/standard/75106.html

International Organization for Standardization e International Electrotechnical Commission. (2022a). Information security, cybersecurity and privacy protection: Information security management systems: Requirements (ISO/IEC 27001:2022). https://www.iso.org/standard/27001

International Organization for Standardization e International Electrotechnical Commission. (2022b). Information security, cybersecurity and privacy protection: Information security controls (ISO/IEC 27002:2022). https://www.iso.org/standard/75652.html

International Organization for Standardization e International Electrotechnical Commission. (2022c). Information security, cybersecurity and privacy

protection: Guidance on managing information security risks (ISO/IEC 27005:2022). https://www.iso.org/standard/80585.html

ISACA. (2018). COBIT 2019 framework: Governance and management objectives. https://www.isaca.org/resources/cobit

Joint Task Force Transformation Initiative. (2012). Guide for conducting risk assessments (NIST Special Publication 800-30 Rev. 1). National Institute of Standards and Technology. https://csrc.nist.gov/pubs/sp/800/30/r1/final

Microsoft. (s. f.-a). Microsoft Deployment Toolkit (MDT): Immediate retirement notice. Microsoft Learn. Recuperado el 10 de octubre de 2026, de https://learn.microsoft.com/en-us/troubleshoot/mem/configmgr/mdt/mdt-retirement

Microsoft. (s. f.-b). Windows Deployment Services (WDS) boot.wim support. Microsoft Learn. Recuperado el 10 de octubre de 2026, de https://learn.microsoft.com/en-us/windows/deployment/wds-boot-support

Microsoft. (2026, 13 de enero). Windows Deployment Services (WDS) hands-free deployment hardening guidance related to CVE-2026-0386. Microsoft Support. Recuperado el 10 de octubre de 2026, de https://support.microsoft.com/en-us/servicing/os/windows/2025/12/windows-deployment-services-wds-hands-free-deployment-hardening-guidance-related-to-cve-2026-0386

Microsoft. (2026). Windows Deployment Services (WDS) deprecation in the next Windows Server release. Microsoft Support. Recuperado el 10 de octubre de 2026, de https://support.microsoft.com/en-us/servicing/os/windows/docs/2026/09/windows-deployment-services-deprecation-in-the-next-windows-server-release

National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0 (NIST CSWP 29). https://csrc.nist.gov/pubs/cswp/29/the-nist-cybersecurity-framework-csf-20/final

Nelson, A., Rekhi, S., Souppaya, M. y Scarfone, K. (2025). Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile (NIST Special Publication 800-61 Rev. 3). National Institute of Standards and Technology. https://csrc.nist.gov/pubs/sp/800/61/r3/final

Oracle. (s. f.). Oracle VirtualBox user guide (versión 7.2) [Manual]. Recuperado el 10 de octubre de 2026, de https://www.virtualbox.org/manual/

Rose, S., Borchert, O., Mitchell, S. y Connelly, S. (2020). Zero trust architecture (NIST Special Publication 800-207). National Institute of Standards and Technology. https://csrc.nist.gov/pubs/sp/800/207/final

Swanson, M., Bowen, P., Phillips, A. W., Gallup, D. y Lynes, D. (2010). Contingency planning guide for federal information systems (NIST Special Publication 800-34 Rev. 1). National Institute of Standards and Technology. https://csrc.nist.gov/pubs/sp/800/34/r1/upd1/final

Telecommunications Industry Association. (2024). ANSI/TIA-942-C: Telecommunications infrastructure standard for data centers. https://tiaonline.org/standard/tia-942/

Universidad Mariano Gálvez de Guatemala. (2026a). Guía didáctica 093-003: Estándares de Seguridad [Documento del curso].

Universidad Mariano Gálvez de Guatemala. (2026b). Proyecto final del curso Estándares de Seguridad: Diseño e implementación de un SGSI [Enunciado del curso].

Lecturas complementarias (no citadas en el texto)

International Organization for Standardization. (2018). Guidelines for auditing management systems (ISO 19011:2018). https://www.iso.org/standard/70017.html

International Organization for Standardization e International Electrotechnical Commission. (2023a). Information technology: Information security incident management: Part 1: Principles and process (ISO/IEC 27035-1:2023). https://www.iso.org/standard/78973.html

International Organization for Standardization e International Electrotechnical Commission. (2023b). Information technology: Information security incident management: Part 2: Guidelines to plan and prepare for incident response (ISO/IEC 27035-2:2023). https://www.iso.org/standard/78974.html

International Organization for Standardization e International Electrotechnical Commission. (2025). Information security, cybersecurity and privacy protection: Guidelines for protection of personally identifiable information (PII) in public clouds acting as PII processors (ISO/IEC 27018:2025). https://www.iso.org/standard/27018

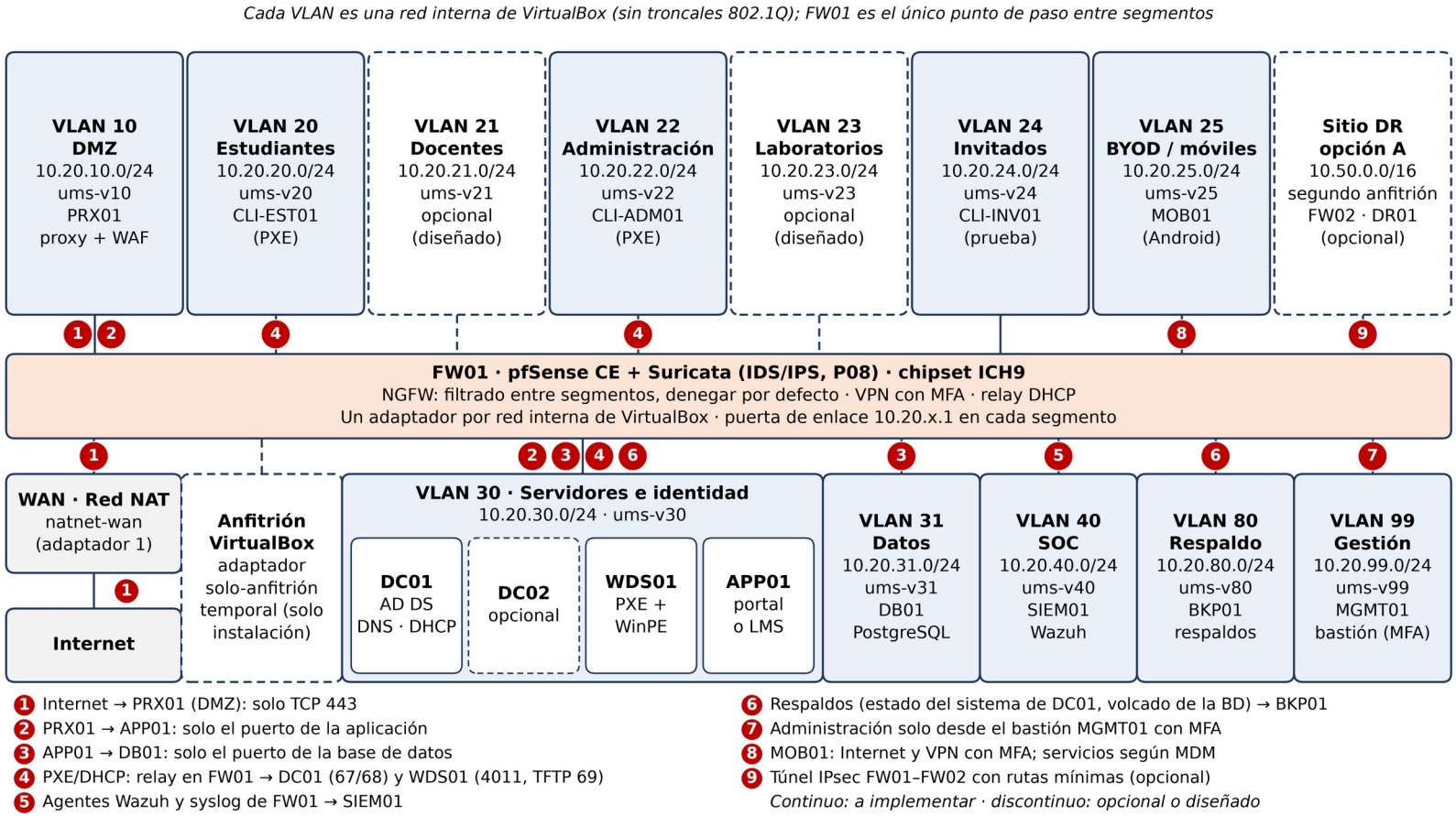
International Organization for Standardization e International Electrotechnical Commission. (2026). Information security, cybersecurity and privacy protection: Information security controls based on ISO/IEC 27002 for cloud services (ISO/IEC 27017:2026). https://www.iso.org/standard/82878.html

Joint Task Force. (2020). Security and privacy controls for information systems and organizations (NIST Special Publication 800-53 Rev. 5). National Institute of Standards and Technology. https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final

Anexo A. Figura 1 a página completa

Figura A1

Topología propuesta del laboratorio en VirtualBox (reproducción a página completa de la Figura 1)



Nota. Misma figura que la Figura 1 (apartado 5.2.3 de esta guía), en alta resolución y a mayor tamaño para facilitar su lectura impresa; elaboración propia. No es una evidencia de implementación.

Anexo B. Hoja de direccionamiento propuesta

Esta hoja responde a la «hoja de direccionamiento y nombres» que pide P00 (Tabla 8). Las subredes son las de la Tabla 5; las puertas de enlace y las IP fijas son una propuesta del grupo que debe confirmarse o ajustarse antes de construir, y los valores reales se registran como evidencia de P00.

Tabla B1

Hoja de direccionamiento propuesta para el laboratorio (coherente con la Tabla 5; completar con los valores reales en P00)

Segmento (VLAN y red interna)	Subred	Puerta de enlace (interfaz de FW01)	Equipos con IP fija (propuesta)	Clientes por DHCP
WAN (natnet-wan)	Red NAT de VirtualBox	La asigna la Red NAT	FW01, adaptador 1 (IP asignada por la Red NAT)	—
10 DMZ (ums-v10)	10.20.10.0/24	10.20.10.1	PRX01: 10.20.10.10	—
20 Estudiantes (ums-v20)	10.20.20.0/24	10.20.20.1	—	CLI-EST01: ámbito de DC01 por relay de FW01 (por ejemplo 10.20.20.100 a 10.20.20.199)
21 Docentes (ums-v21), opcional	10.20.21.0/24	10.20.21.1	—	Diseñado (mismo patrón que la VLAN 20)
22 Administración (ums-v22)	10.20.22.0/24	10.20.22.1	—	CLI-ADM01: ámbito de DC01 por relay de FW01 (por ejemplo 10.20.22.100 a 10.20.22.199)
23 Laboratorios (ums-v23), opcional	10.20.23.0/24	10.20.23.1	—	Diseñado
24 Invitados (ums-v24)	10.20.24.0/24	10.20.24.1	—	CLI-INV01: DHCP sin DNS interno (el grupo

Segmento (VLAN y red interna)	Subred	Puerta de enlace (interfaz de FW01)	Equipos con IP fija (propuesta)	Clientes por DHCP
				decide si lo entrega FW01 o DC01 por relay; registrarlo en P04)
25 BYOD / móviles (ums-v25)	10.20.25.0/24	10.20.25.1	—	MOB01: DHCP sin DNS interno (misma decisión que en la VLAN 24)
30 Servidores e identidad (ums-v30)	10.20.30.0/24	10.20.30.1	DC01: 10.20.30.10; DC02 (opcional): 10.20.30.11; WDS01: 10.20.30.20; APP01: 10.20.30.30	—
31 Datos (ums-v31)	10.20.31.0/24	10.20.31.1	DB01: 10.20.31.10	—
40 SOC (ums-v40)	10.20.40.0/24	10.20.40.1	SIEM01: 10.20.40.10	—
80 Respaldo (ums-v80)	10.20.80.0/24	10.20.80.1	BKP01: 10.20.80.10	—
99 Gestión (ums-v99)	10.20.99.0/24	10.20.99.1	MGMT01: 10.20.99.10	—
Sitio DR (segundo anfitrión), opcional	10.50.0.0/16	Interfaz interna de FW02 (por ejemplo 10.50.0.1)	DR01 (opcional): por ejemplo 10.50.0.10	—

Nota. Propuesta del grupo; elaboración propia. Convención: .1 para la interfaz de FW01 en cada segmento, .10 a .30 para servidores y .100 a .199 para ámbitos DHCP. DHCP 67/68 y PXE solo se permiten según la matriz de flujos (apartado 5.2.5 de esta guía). Si se aplica la opción 2 de la Tabla 6, agregar las direcciones del enlace de tránsito entre FW01 y FW01b.